# 🌐 Module 06: API and Java Web Token Penetration Testing

```
# Exercise 05: Exploiting Insecure JSON Web Token(JWT) Implementations
```

### Scenario

JSON Web Tokens (**JWTs**) are compact, URL-safe tokens used for stateless user authentication and session management in modern microservices and web APIs. A standard JWT consists of three Base64URL-encoded parts separated by periods: `Header.Payload.Signature`.

Insecure JWT implementations often fail to strictly enforce signature validation or improperly accept tokens with the algorithm header (`alg`) modified to `<font color="#ffd700"><b>none</b></font>`. When an API backend accepts unsigned tokens (`alg: none`), an attacker can tamper with user claims inside the payload (e.g., impersonating an admin or non-existent user like `<font color="#ffd700"><b>jwtn3d@juice-sh.op</b></font>`), strip the signature block, and achieve full authentication bypass.

In this exercise, we intercept JWT authorization headers in Burp Suite from OWASP Juice Shop (`http://192.168.0.19`), decode tokens using `jwt.io`, identify the default signing algorithm (**RS256**), modify header parameters to **none**, tamper with user email claims, re-encode payloads using Base64URL, and submit forged unsigned tokens to complete the challenge.

### Objective

The objective of this lab is to help students learn how to:
- Intercept and extract HTTP `Authorization: Bearer` JWT authentication tokens using Burp Suite
- Decode JWT headers and payloads using online tools (`jwt.io`) to inspect claims and algorithms
- Identify default asymmetric signing algorithms (**RS256**)
- Execute an `alg: none` JWT signature bypass attack by altering token headers and payloads
- Construct Base64URL-encoded unsigned JWT payloads (`Header.Payload.`) and achieve user forgery (**jwtn3d@juice-sh.op**)

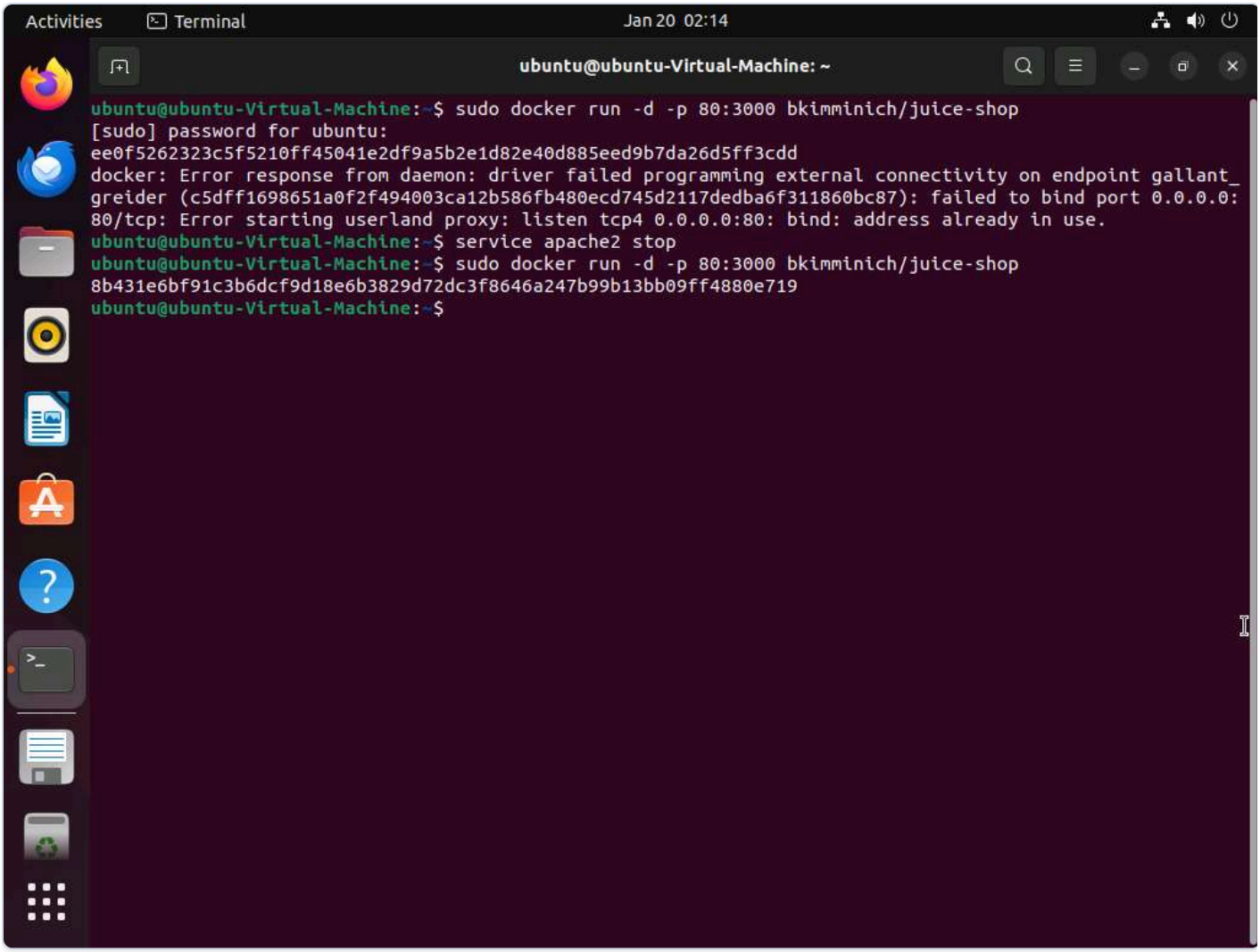
---

## Task 1: Forge Unsigned JWT for User Impersonation

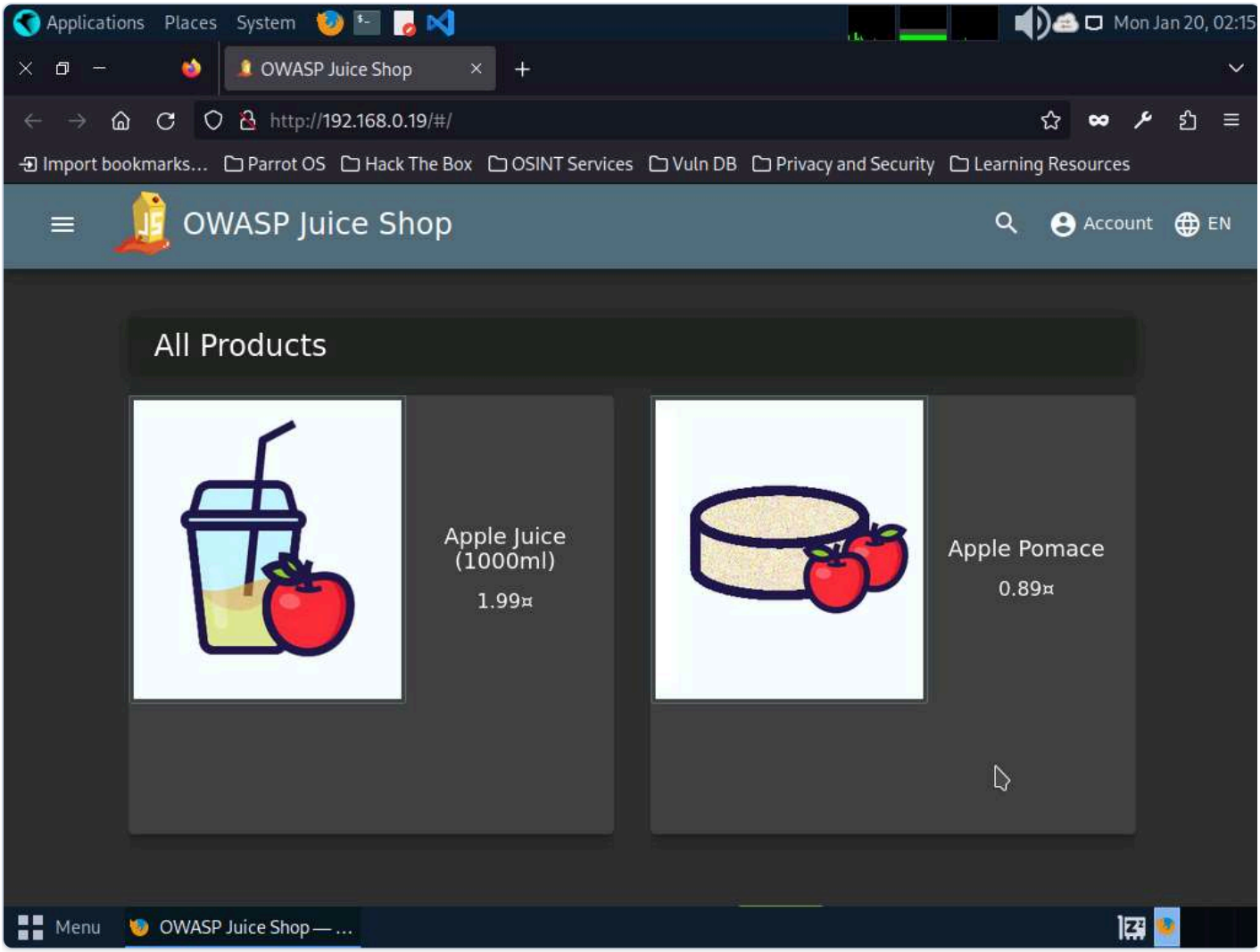
In this task, we launch Juice Shop on Ubuntu, intercept authentication traffic in Burp Suite on Parrot Security, alter JWT headers and payloads via `jwt.io` and Base64URL encoders, submit forged Bearer tokens in Repeater, and verify scoreboard completion.

### Lab Tasks

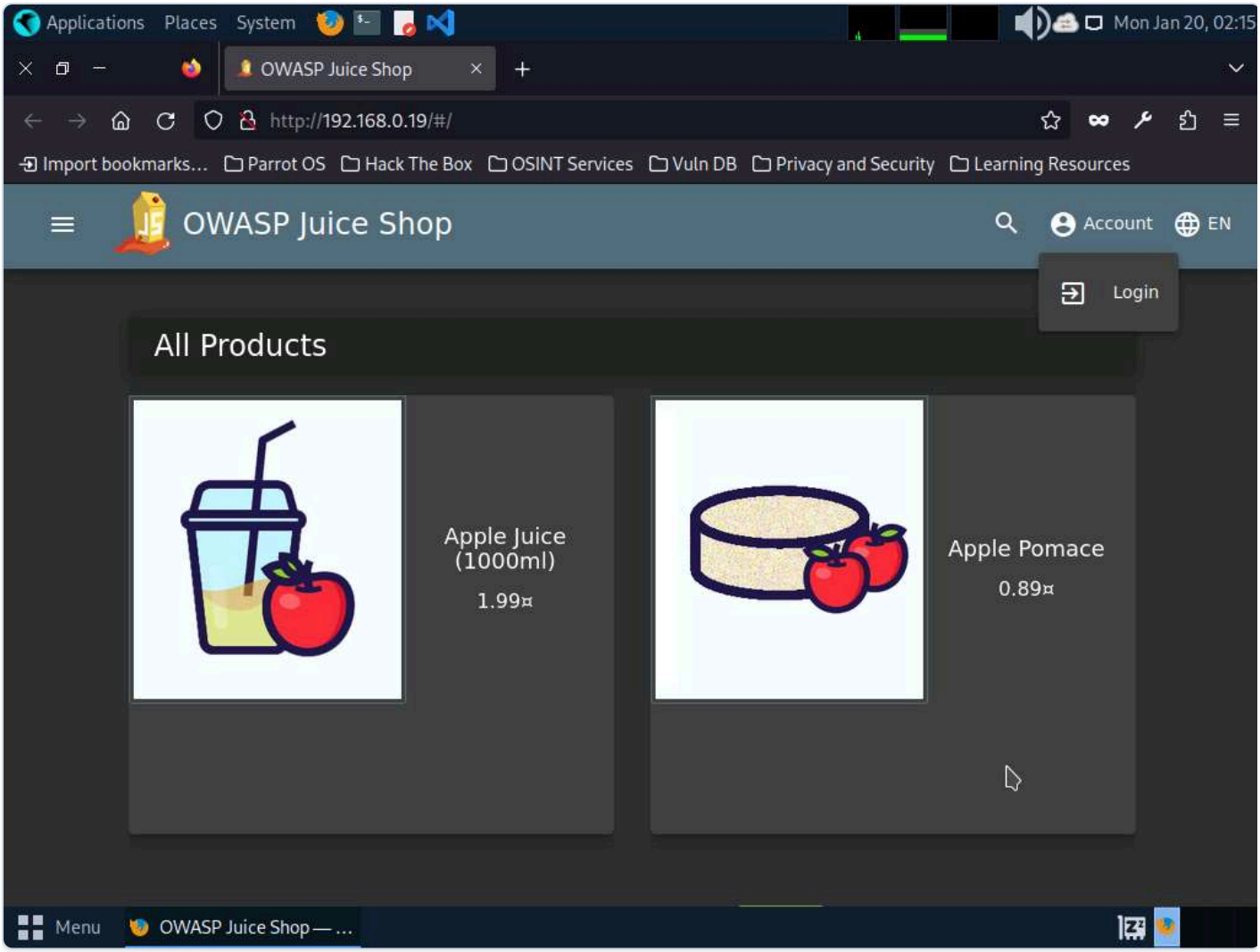
1. Switch to **Ubuntu** (**ubuntu** / **toor**), open a terminal elevated to root (**sudo su**), stop apache2 if necessary (**service apache2 stop**), and run Juice Shop:
   **sudo docker run -d -p 80:3000 bkimminich/juice-shop**



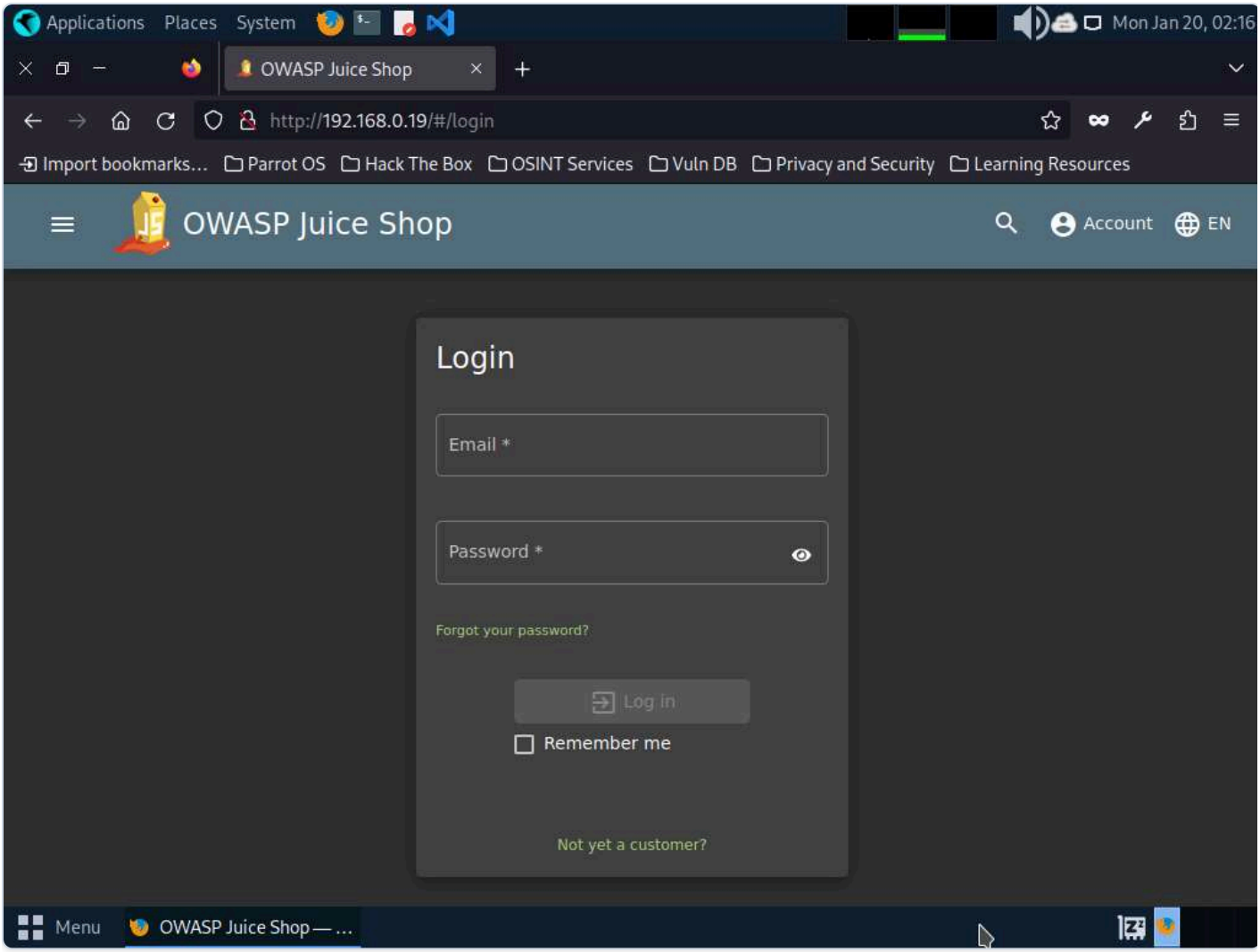

1. Switch to **Parrot Security** (**pentester** / **toor**). Open Firefox and navigate to **http://192.168.0.19**. Dismiss the welcome banner.



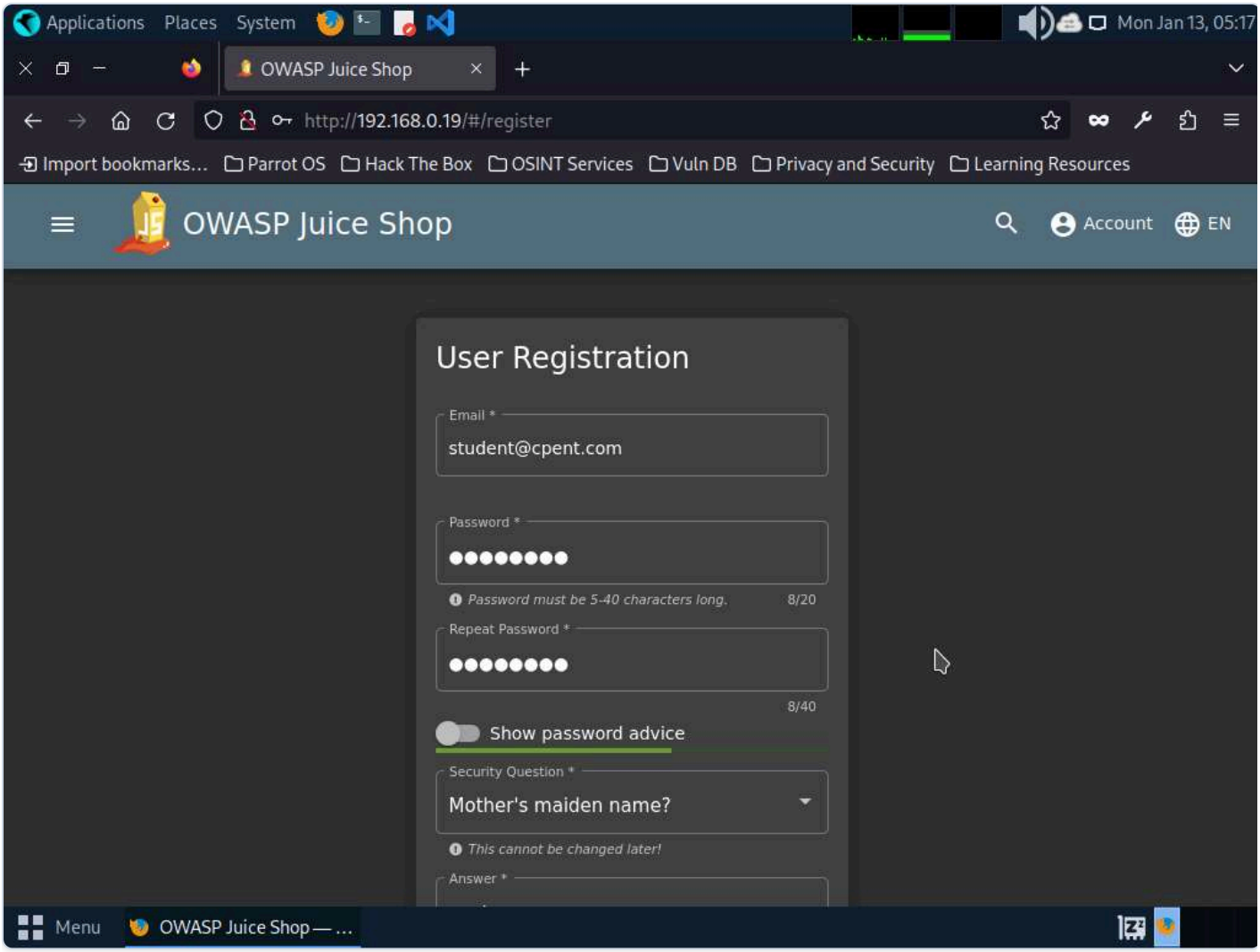

1. Click **Account** $
   ightarrow$ **Login**.



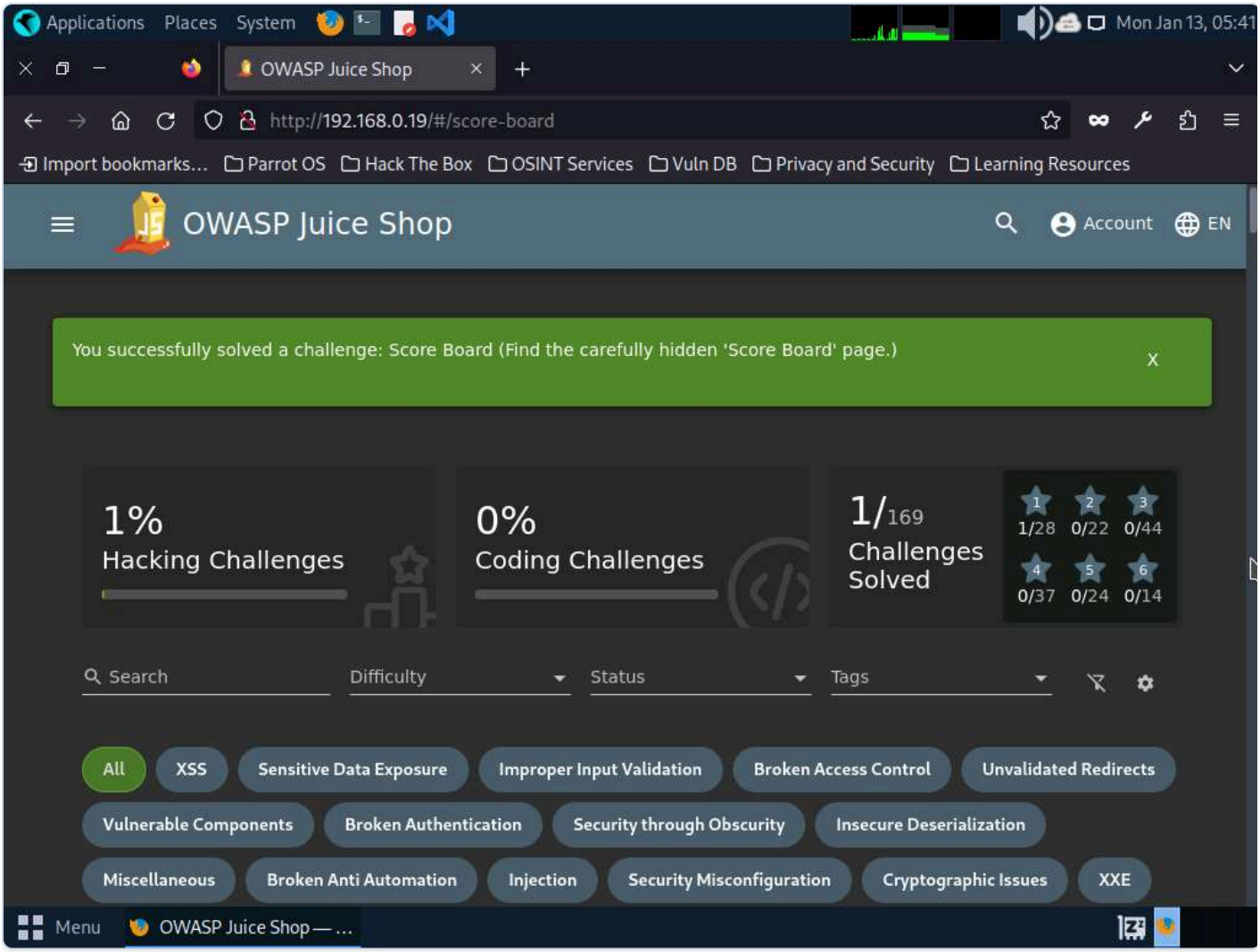

1. Click **Not yet a customer?**.



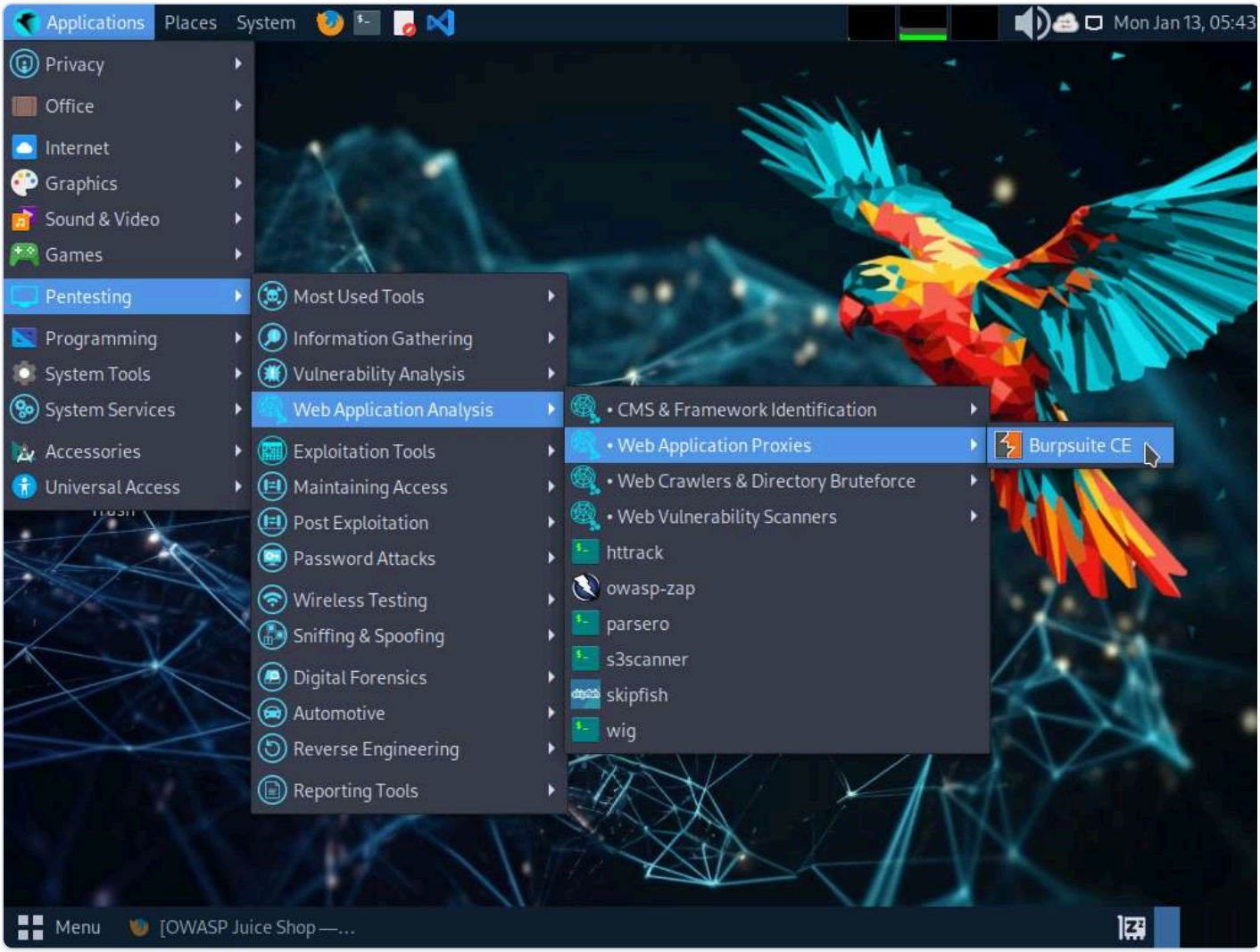

1. Complete the user registration form and click **Register**.

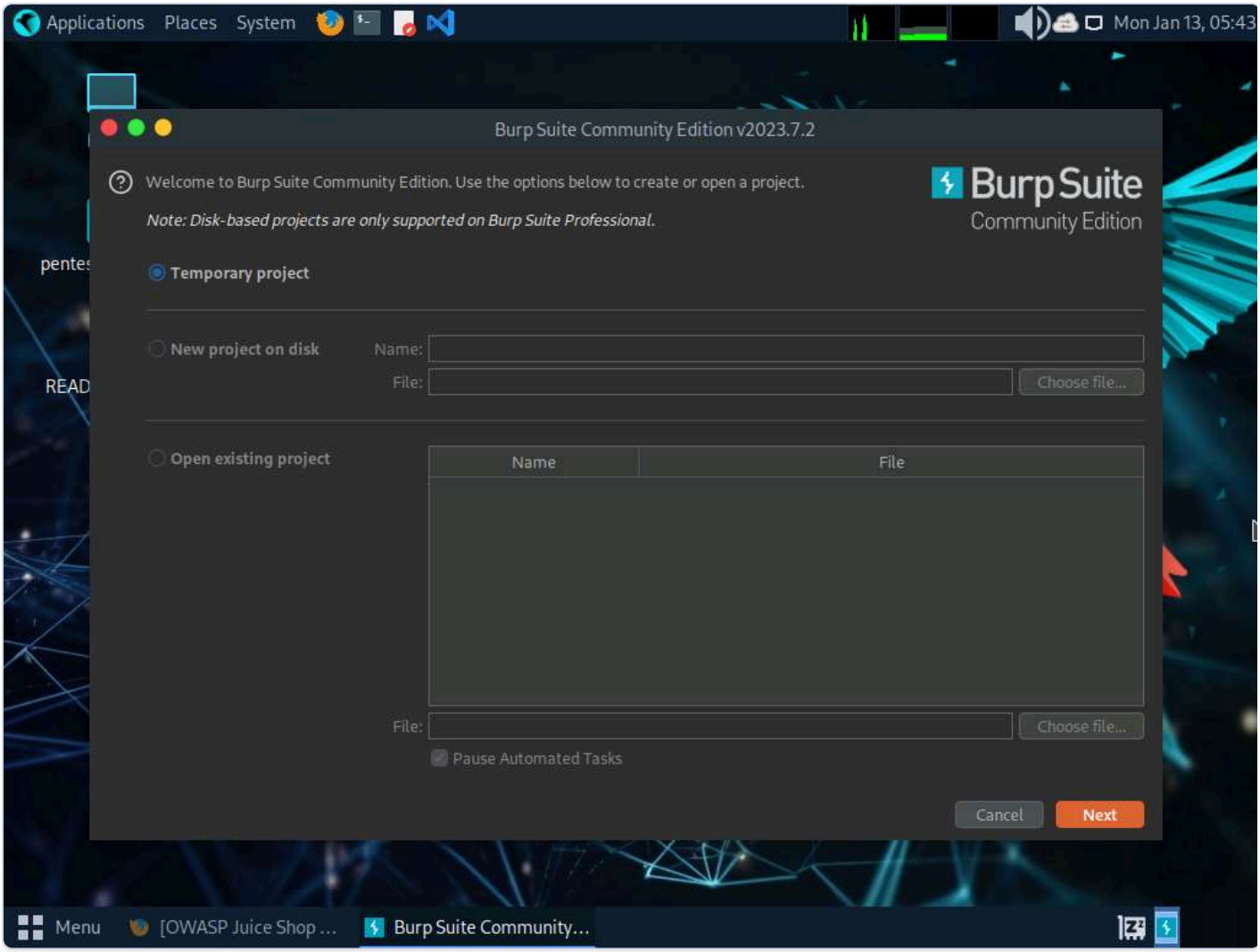


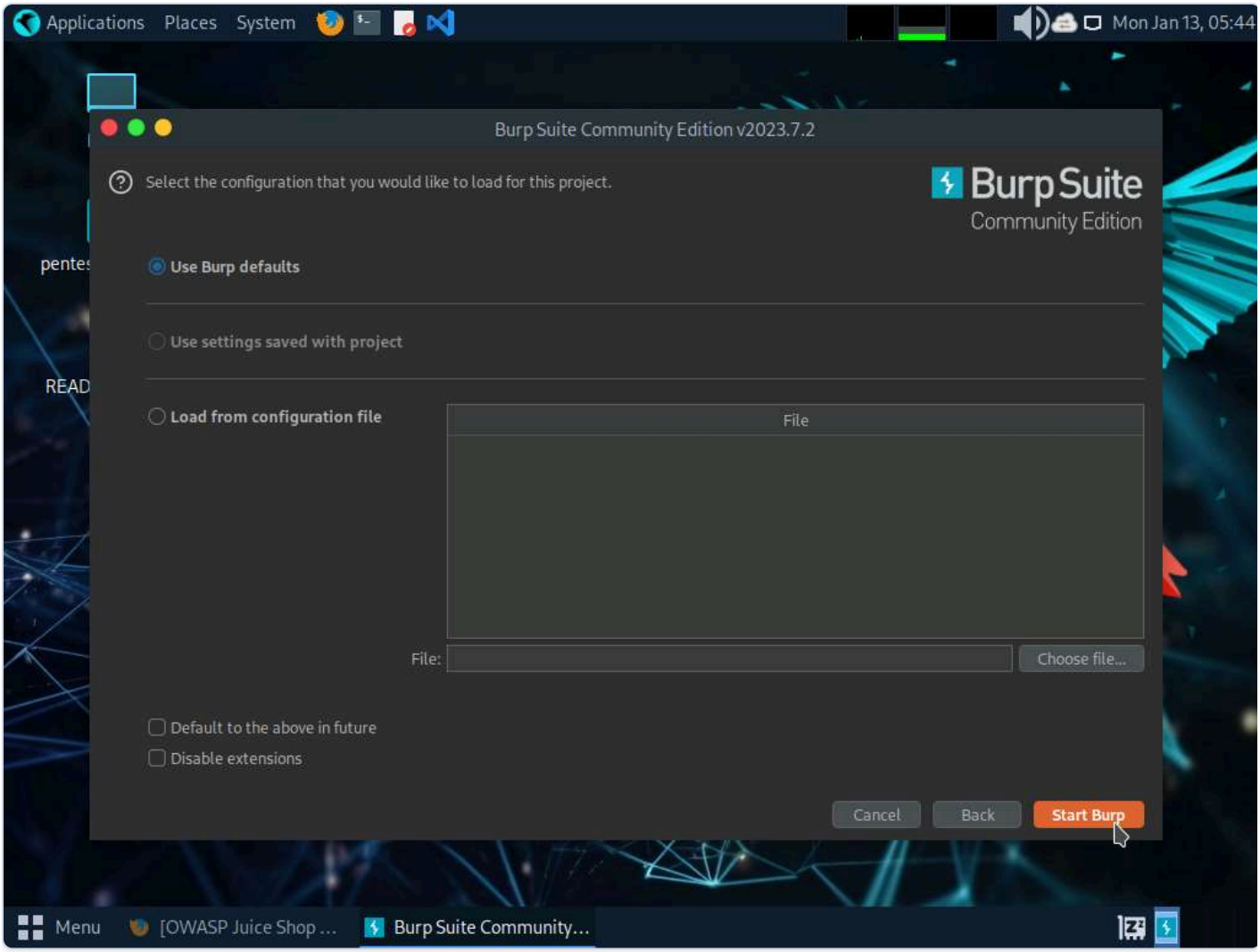

1. Navigate to **http://192.168.0.19/#/score-board** in Firefox.



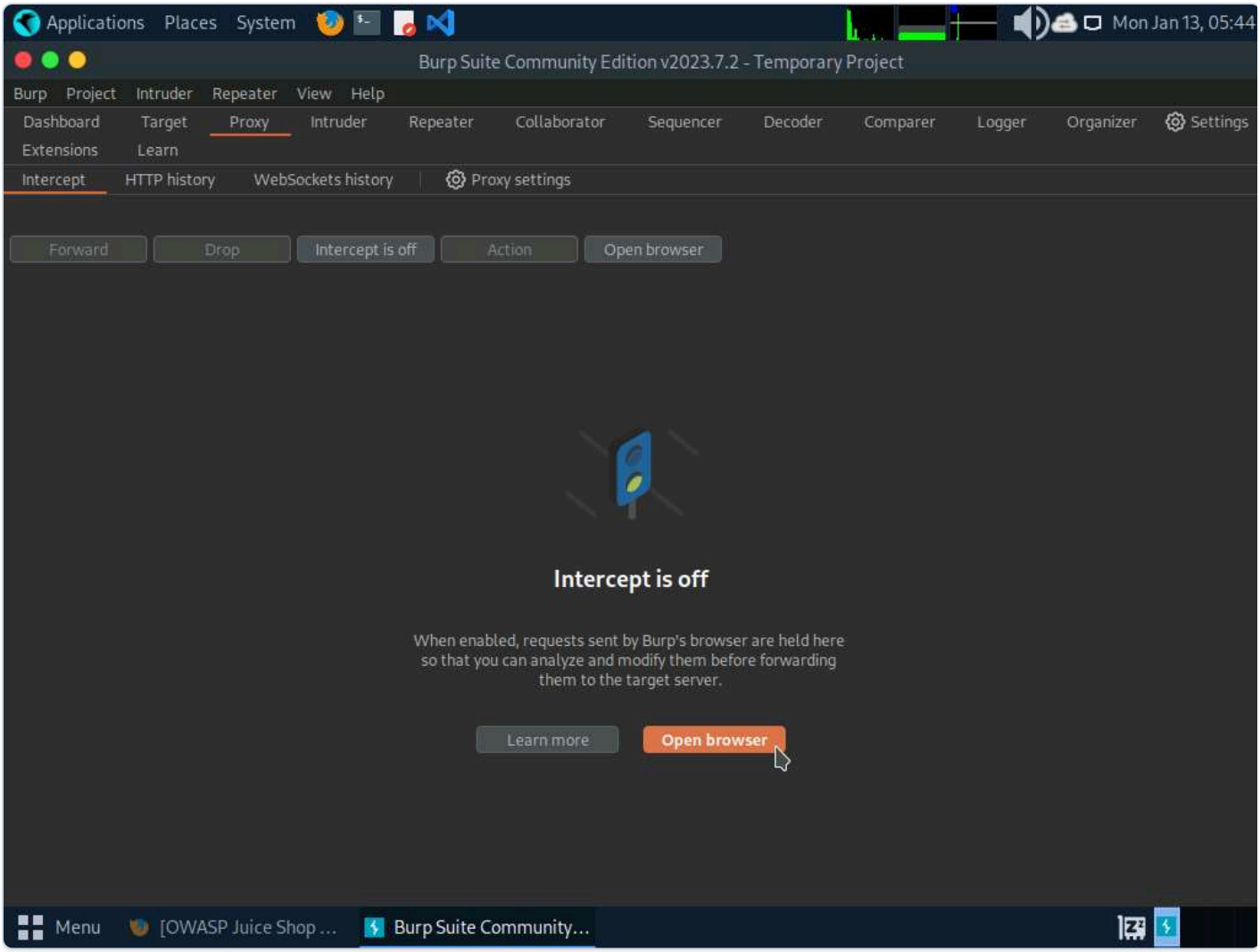

1. Launch **Burp Suite Community Edition** on Parrot Security. Select **Temporary project** and click **Start Burp**.


Applications
Places
System
Mon Jan 13, 05:43
Privacy
Office
Internet
Graphics
Sound & Video
Games
Pentesting
Programming
System Tools
System Services
Accessories
Universal Access
Most Used Tools
Information Gathering
Vulnerability Analysis
Web Application Analysis
Exploitation Tools
Maintaining Access
Post Exploitation
Password Attacks
Wireless Testing
Sniffing & Spoofing
Digital Forensics
Automotive
Reverse Engineering
Reporting Tools
• CMS & Framework Identification
• Web Application Proxies
• Web Crawlers & Directory Bruteforce
• Web Vulnerability Scanners
httrack
owasp-zap
parsero
s3scanner
skipfish
wig
Burpsuite CE
Menu
[OWASP Juice Shop —...

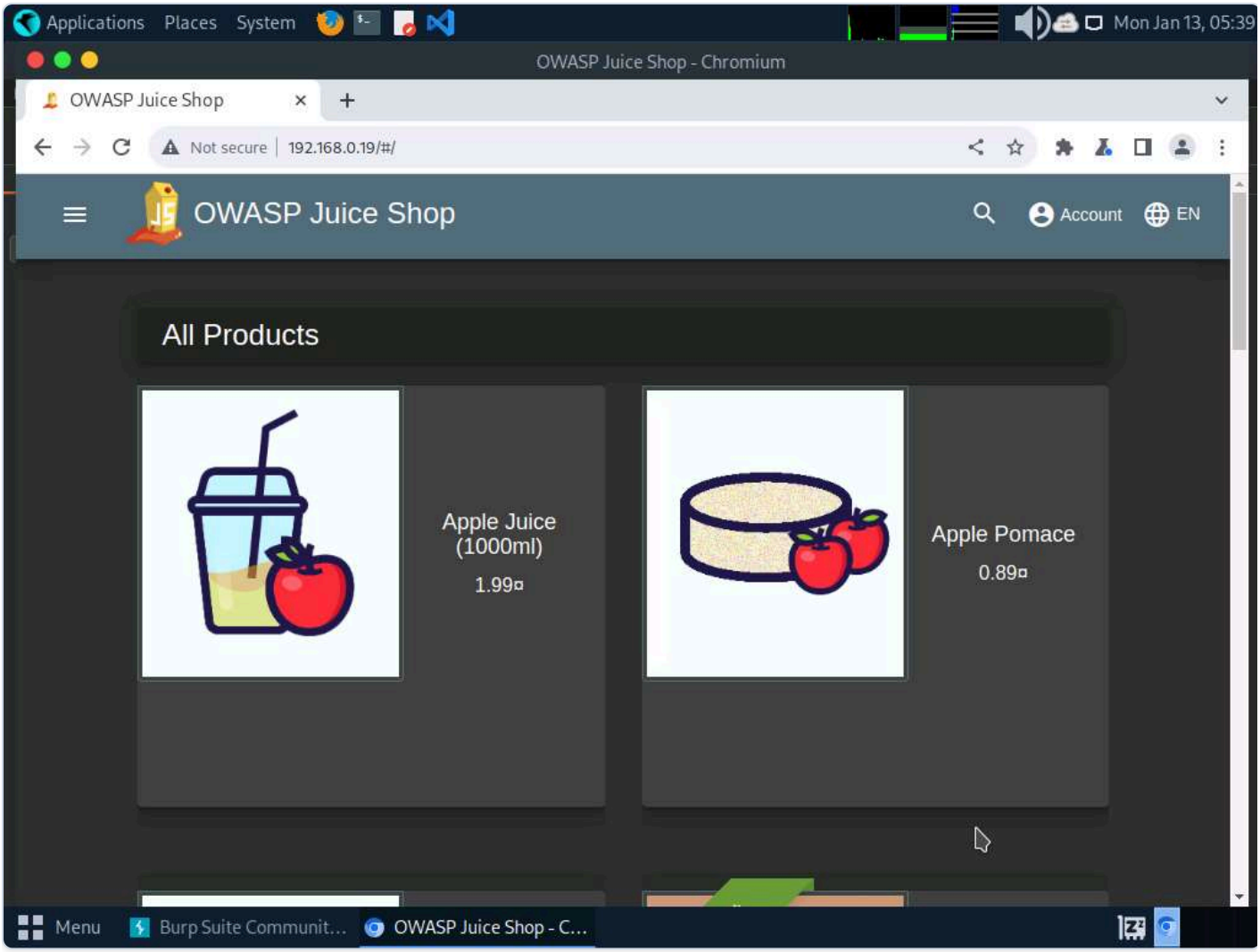

Applications
Places
System
Mon Jan 13, 05:43
Burp Suite Community Edition v2023.7.2
Welcome to Burp Suite Community Edition. Use the options below to create or open a project.
Note: Disk-based projects are only supported on Burp Suite Professional.
Burp Suite
Community Edition
Temporary project
New project on disk
Name:
File:
Choose file...
Open existing project
Name
File
File:
Choose file...
Pause Automated Tasks
Cancel
Next
Menu
[OWASP Juice Shop ...
Burp Suite Community...



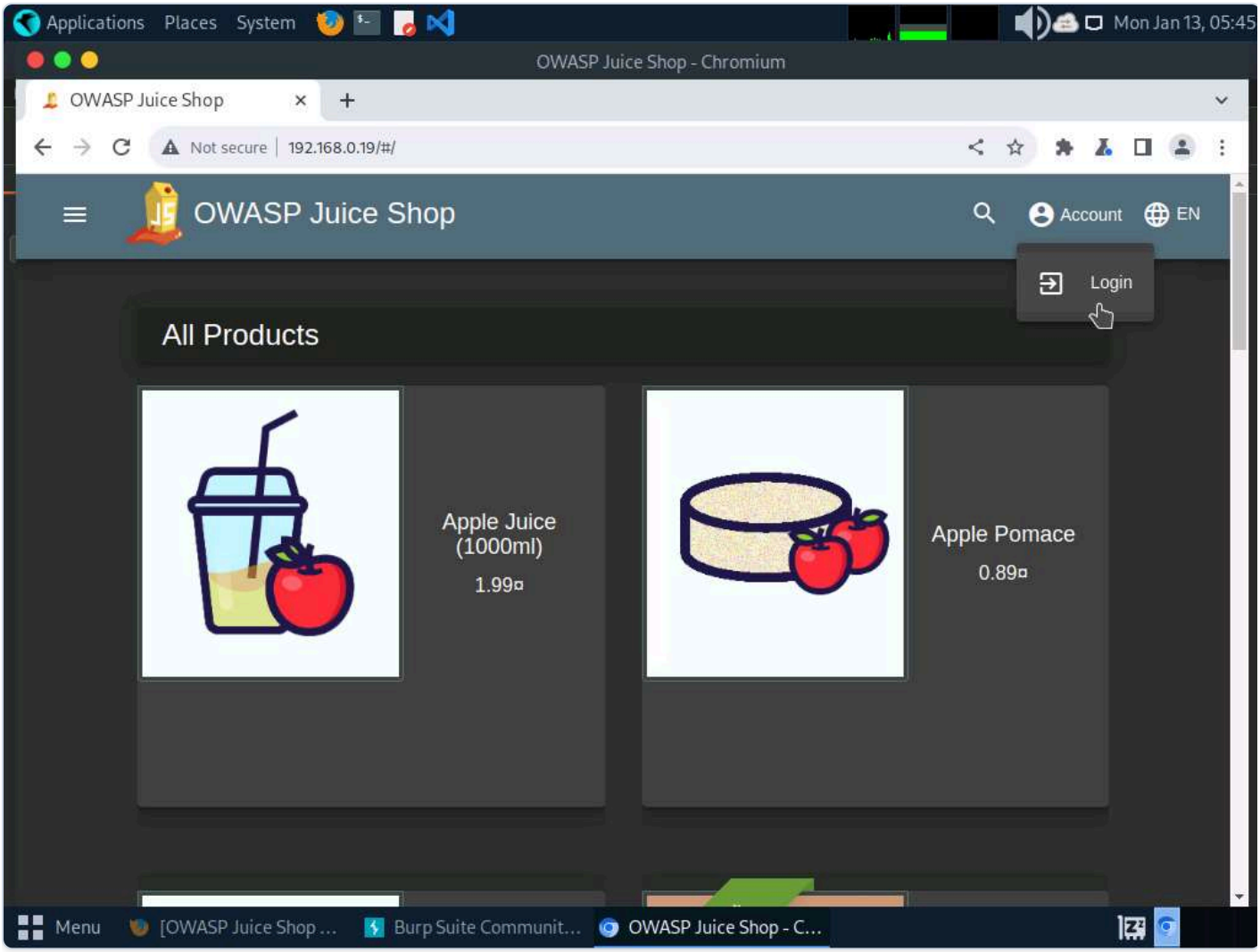

1. Navigate to **Proxy** tab $
   ightarrow$ turn **Intercept is OFF**, and click **Open Browser**.



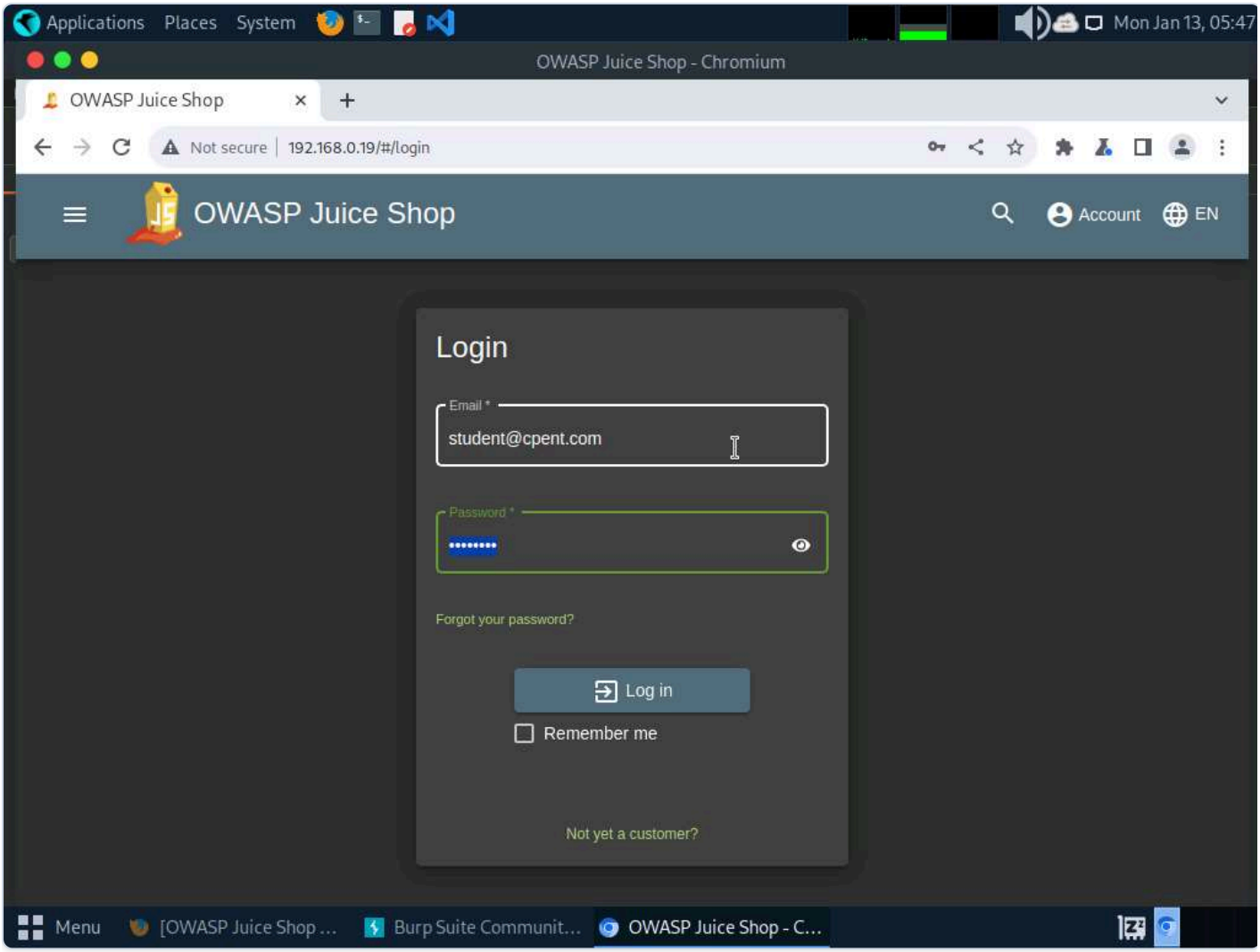

1. In the Burp Chromium Browser, open **http://192.168.0.19**.



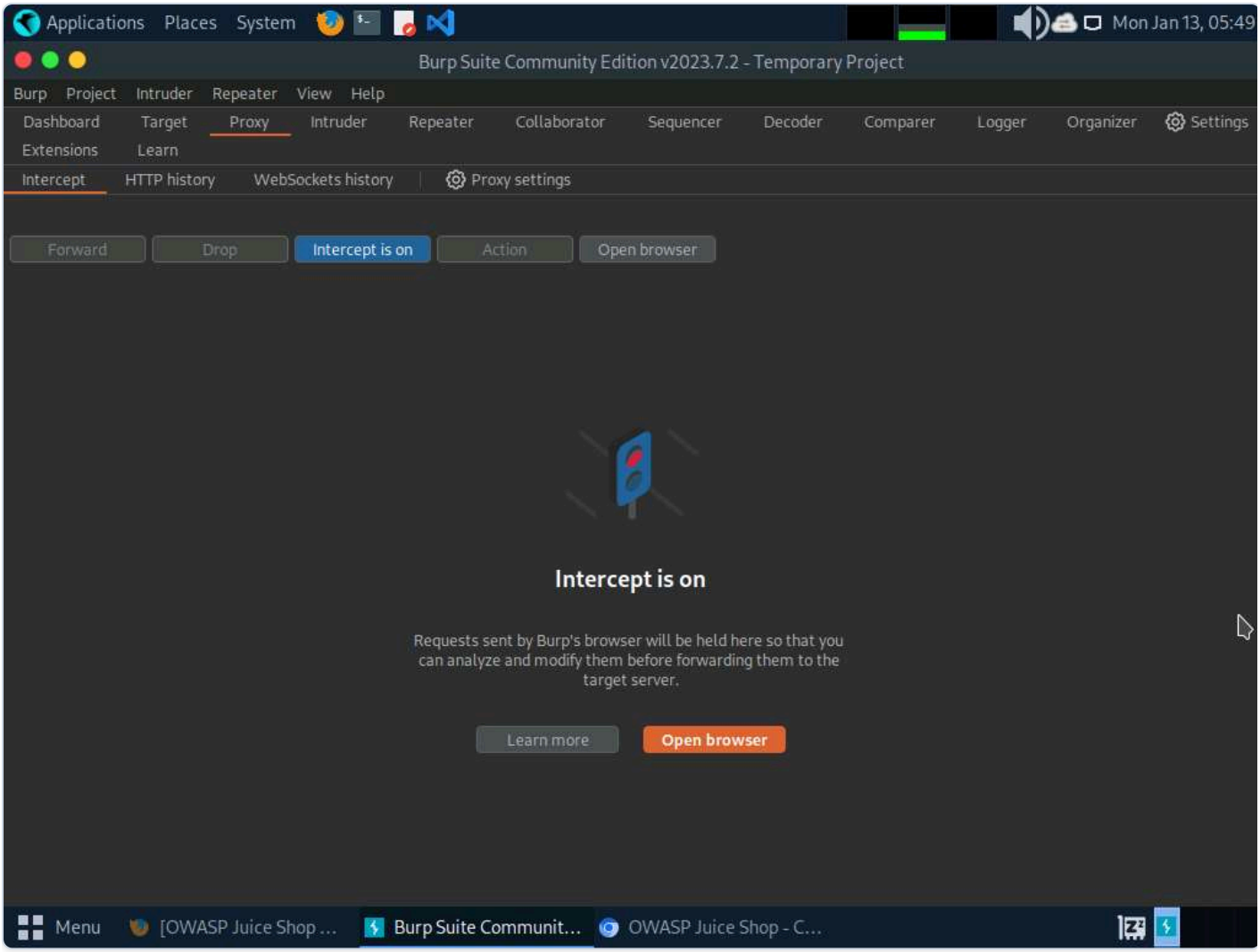

1. Click **Account** $
   ightarrow$ **Login**.

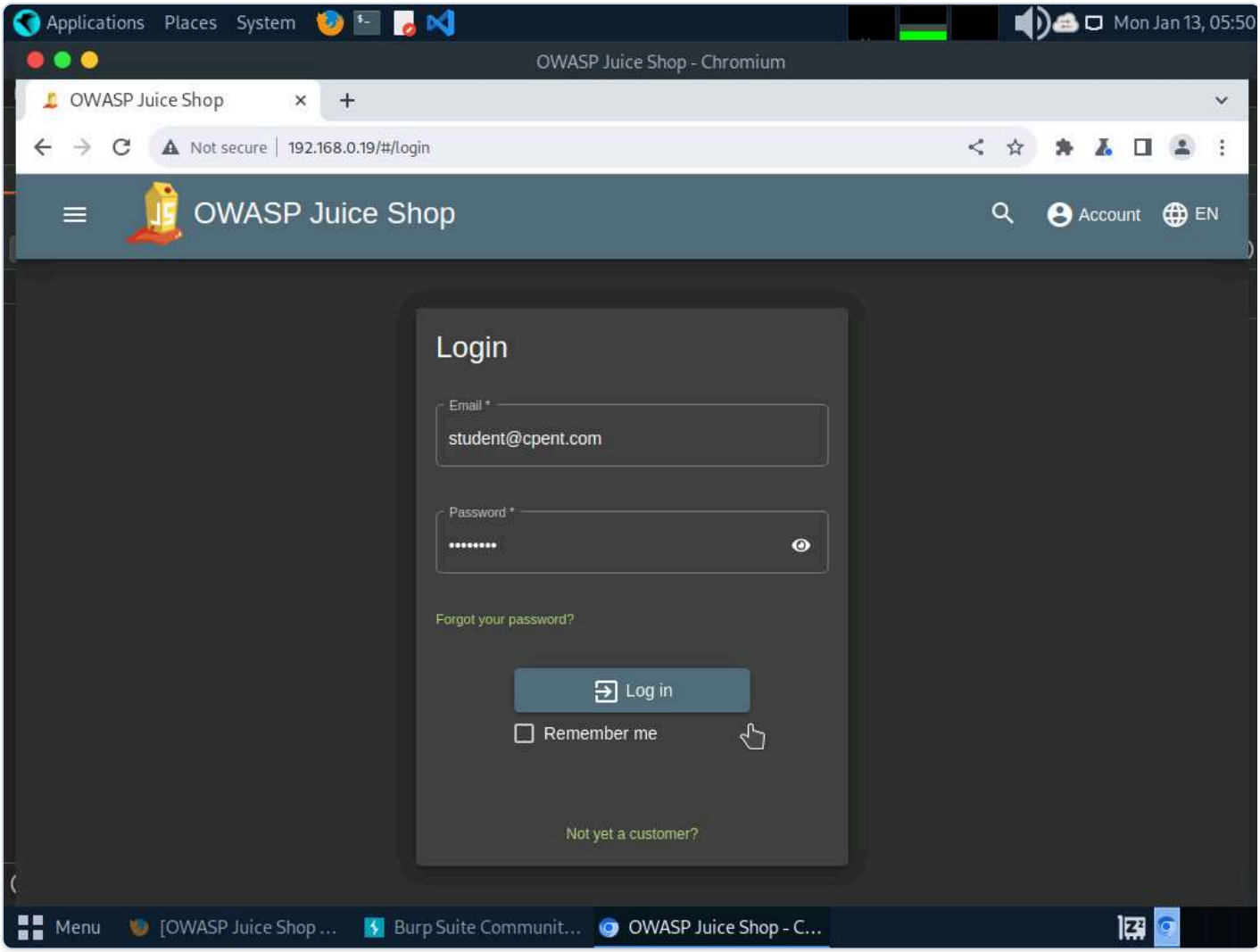



1. Fill in your registered Email address and Password.

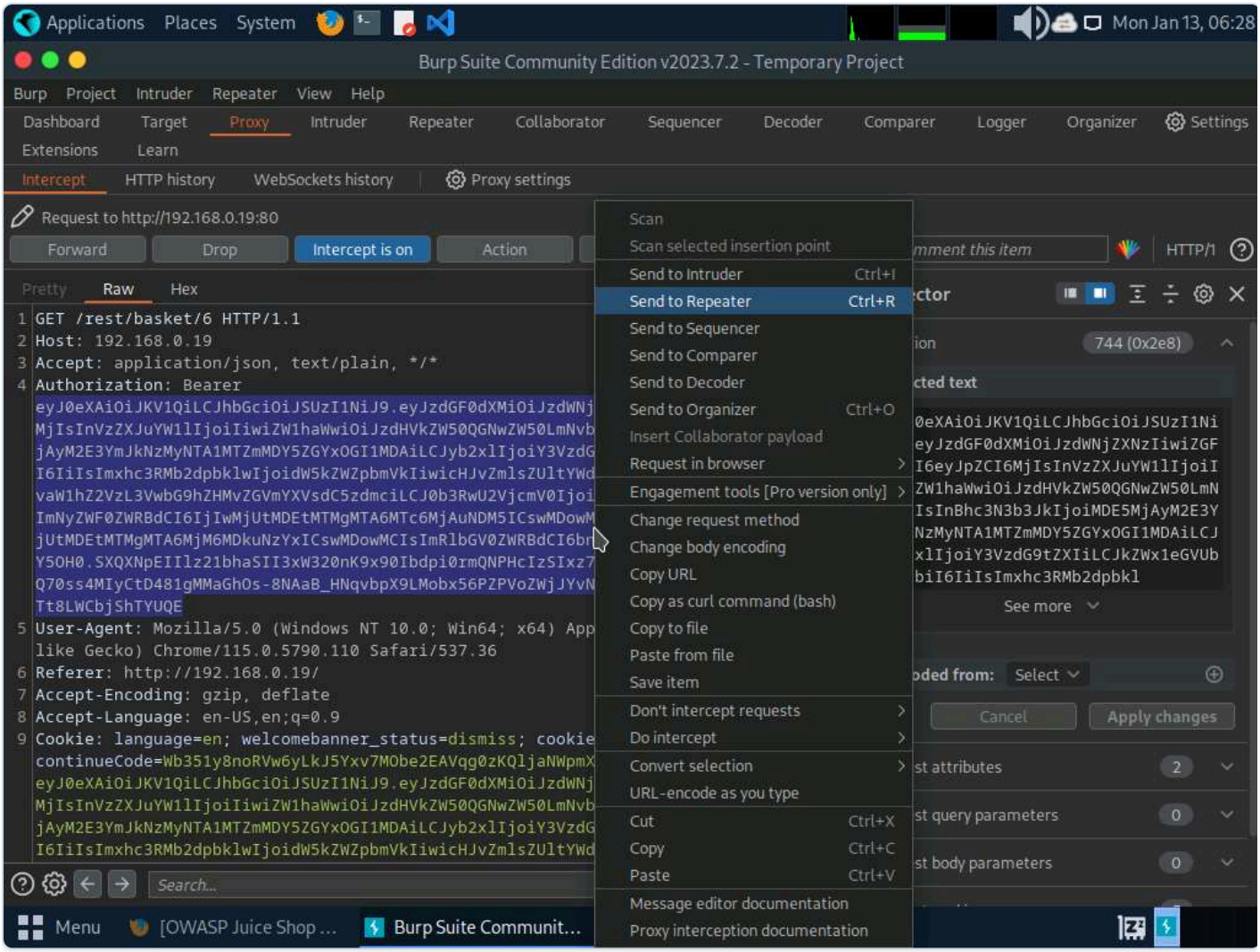



1. Switch to Burp Proxy and set **Intercept is ON**. Return to the browser and click **Log in**.

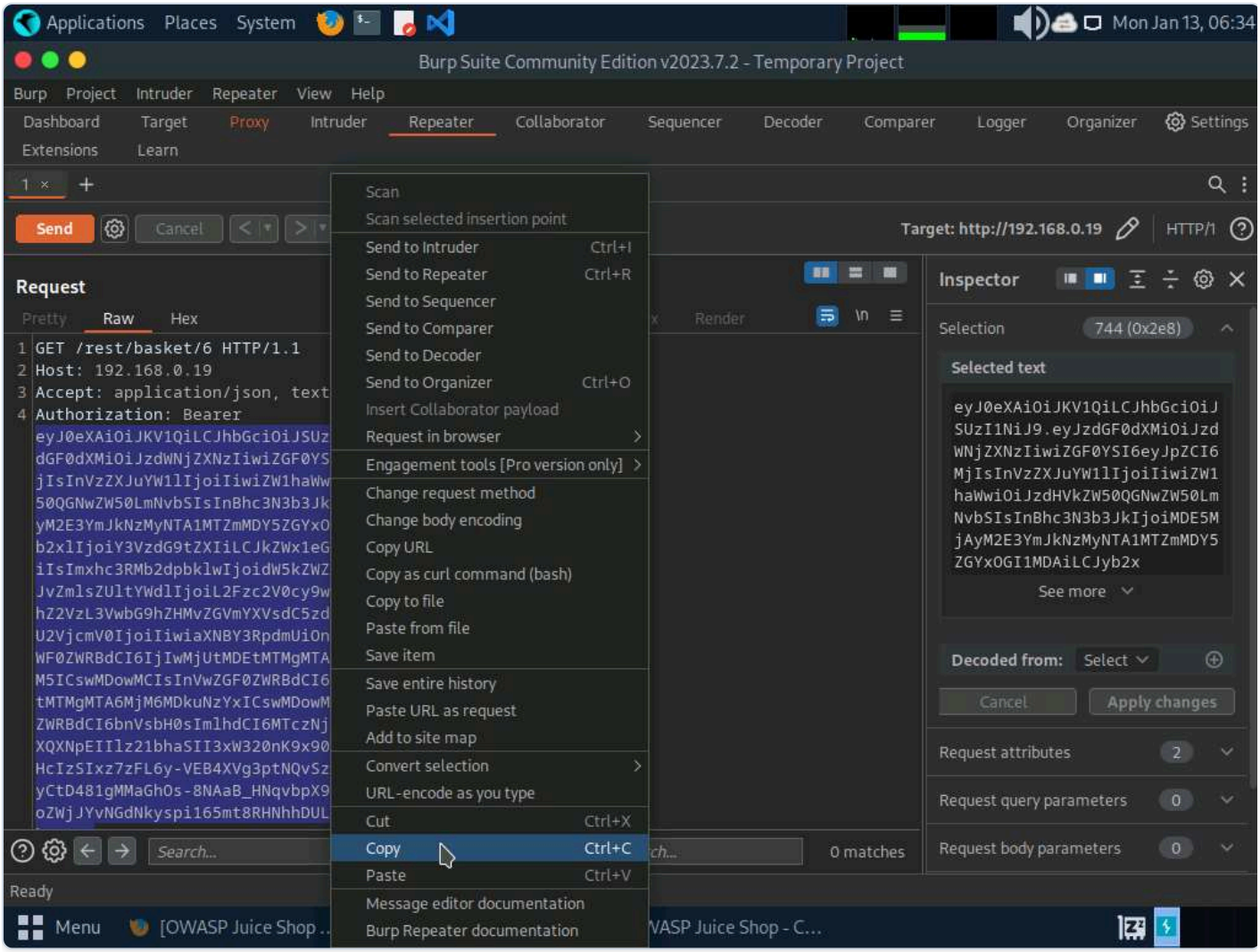

Applications Places System
Mon Jan 13, 05:49
Burp Suite Community Edition v2023.7.2 - Temporary Project
Burp Project Intruder Repeater View Help
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Settings
Extensions Learn
Intercept HTTP history WebSockets history Proxy settings
Forward Drop Intercept is on Action Open browser
Intercept is on
Requests sent by Burp's browser will be held here so that you can analyze and modify them before forwarding them to the target server.
Learn more
Open browser
Menu
[OWASP Juice Shop ...
Burp Suite Communit...
OWASP Juice Shop - C...



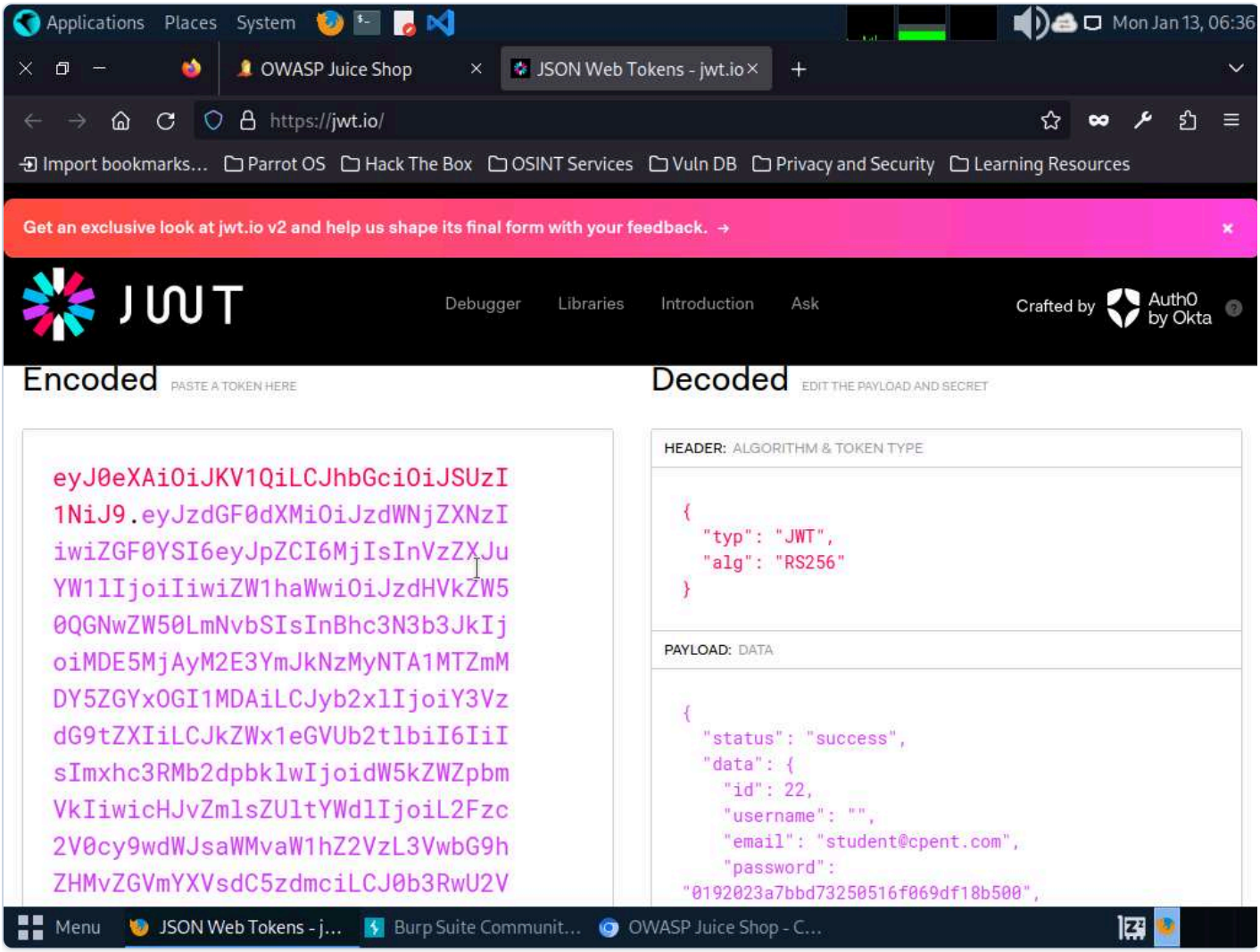

1. In Burp Proxy Intercept, click **Forward** until capturing a request containing **Authorization: Bearer**. Right-click the request and select **Send to Repeater**.



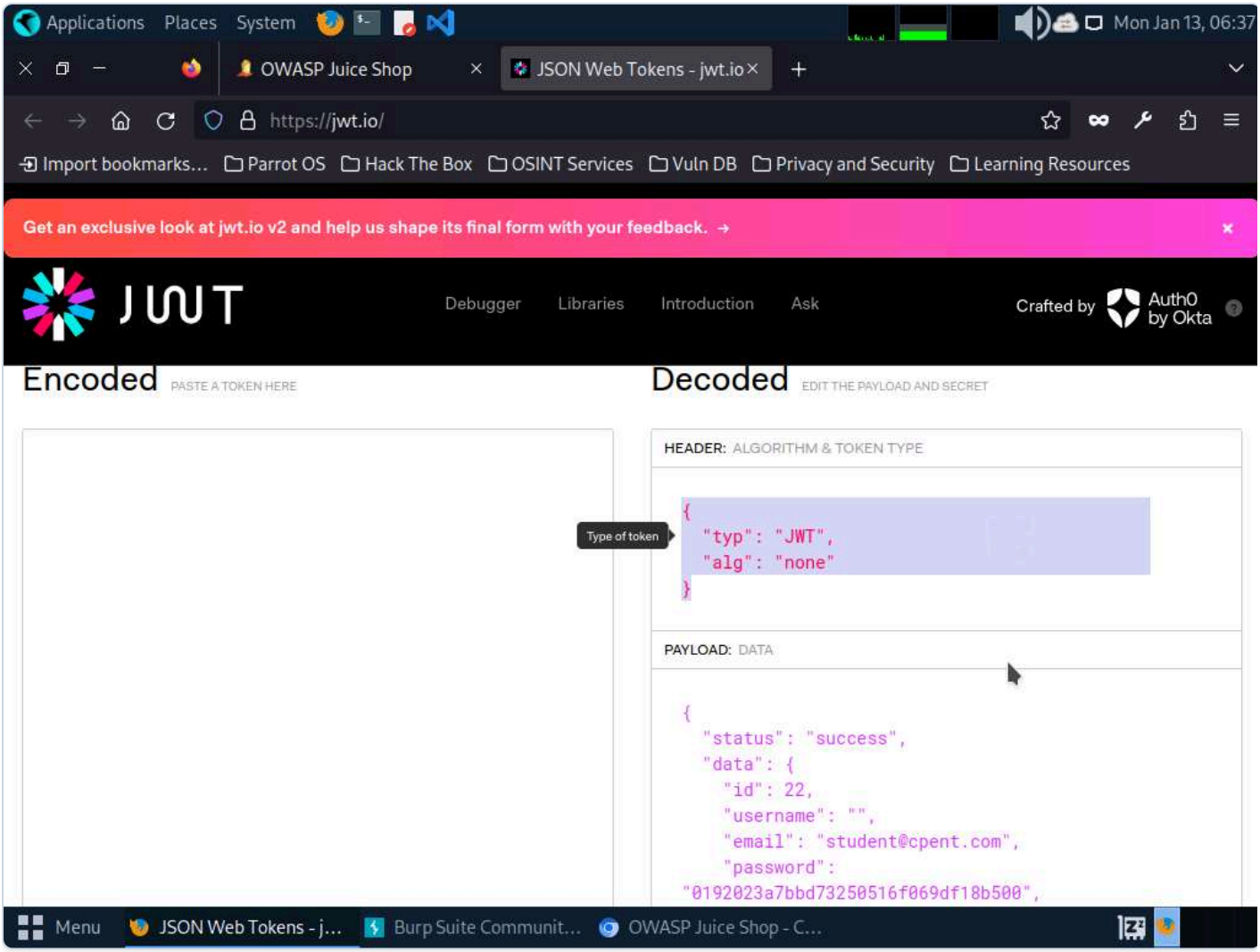

1. Go to **Repeater** tab and copy the complete Bearer token string.



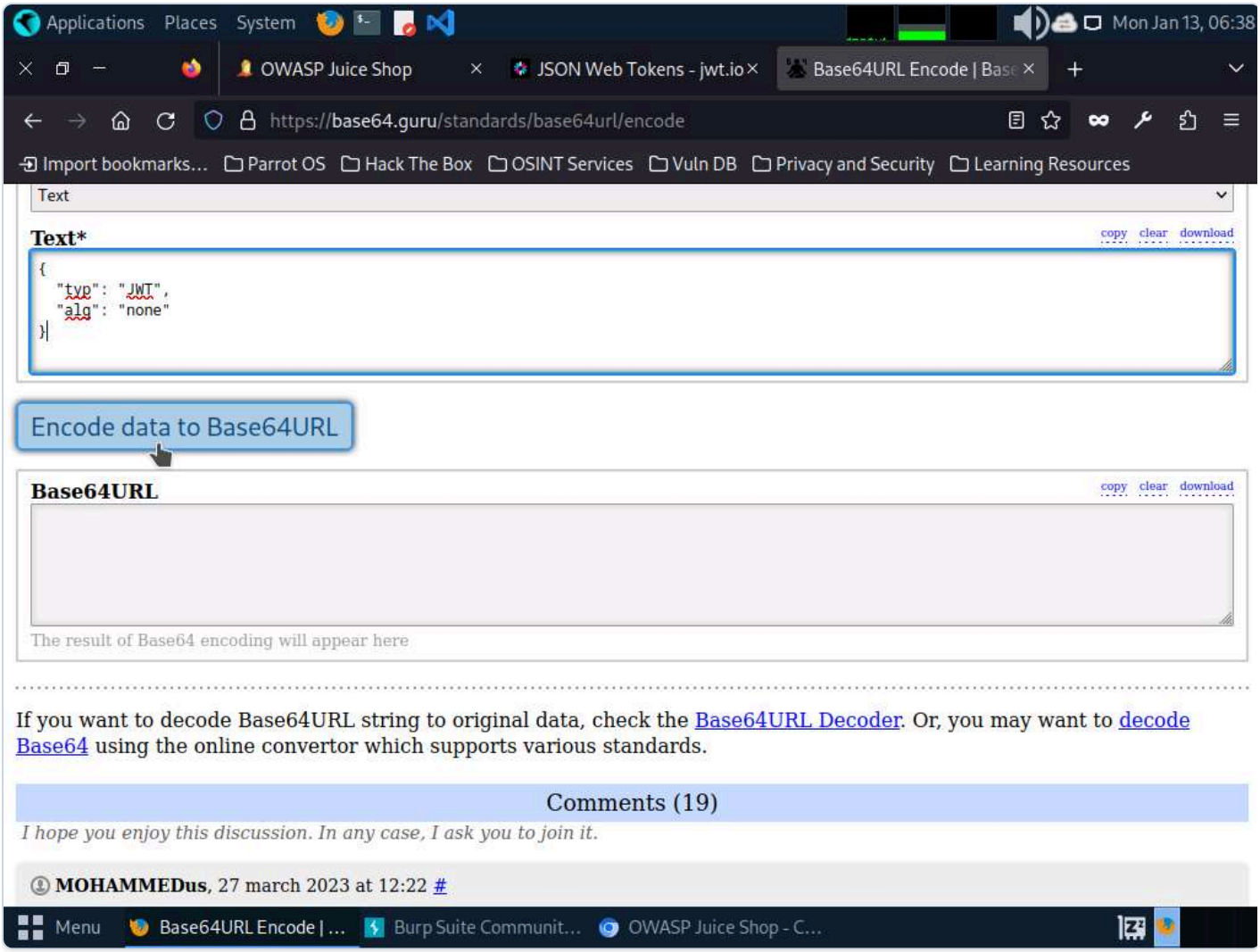

1. Navigate to **https://jwt.io** and paste the intercepted token into the Encoded pane. Observe that the default header algorithm is **RS256**.



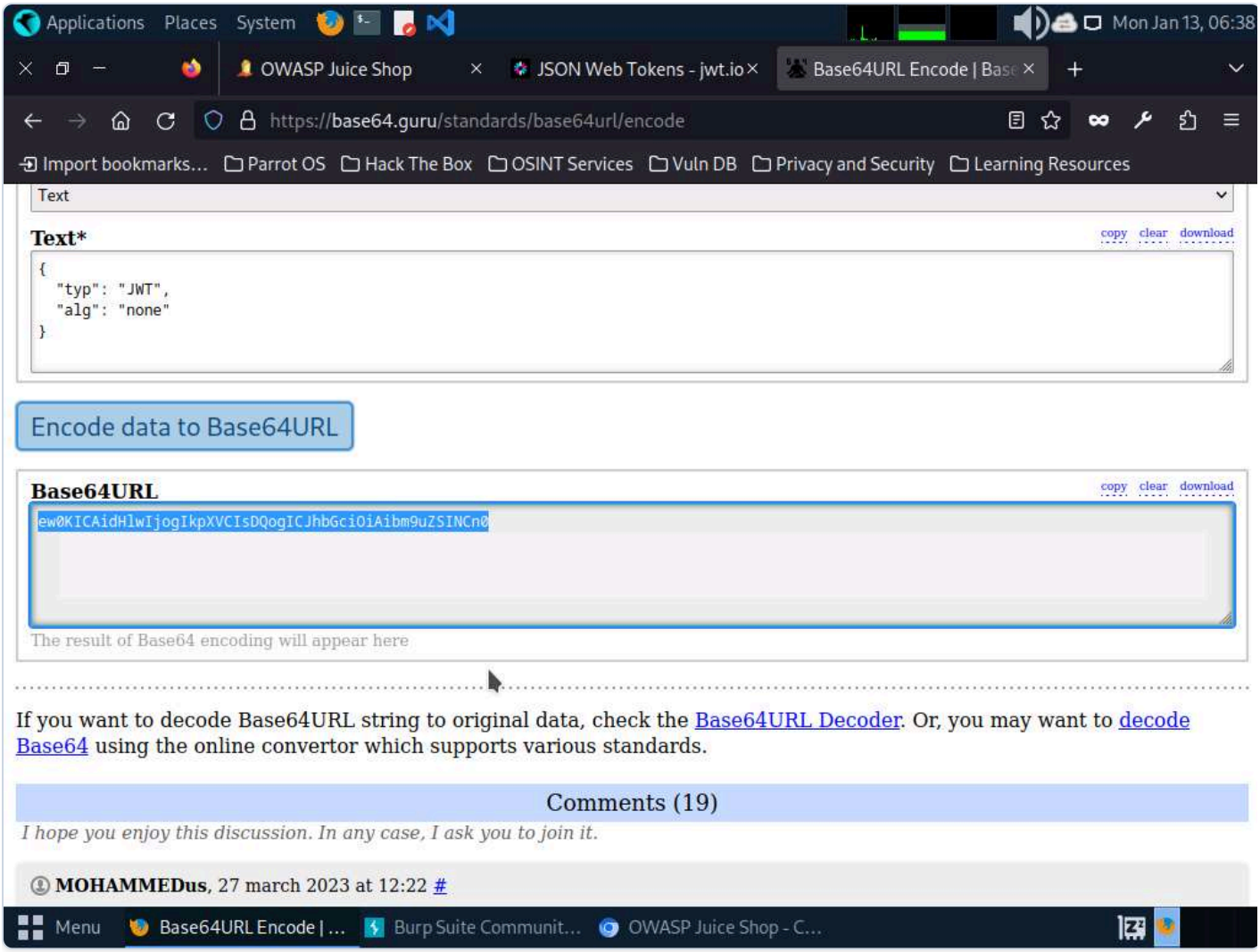

1. In the Decoded Header pane, change `"alg": "RS256"` to **`"alg": "none"`**:
   `json { "alg": "none", "typ": "JWT" }`



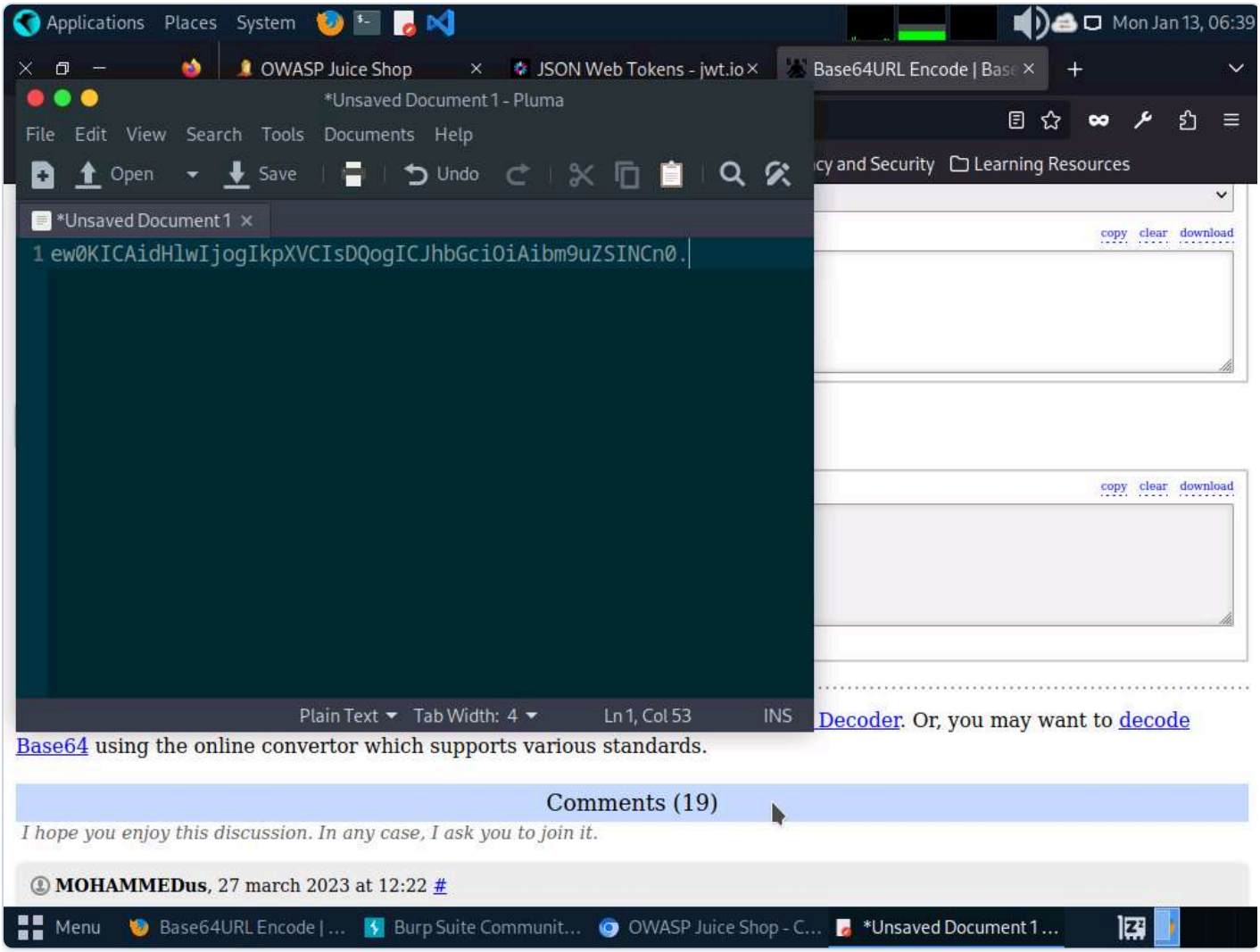

1. Open **https://base64.guru/standards/base64url/encode**, paste the modified header JSON, and click Encode.



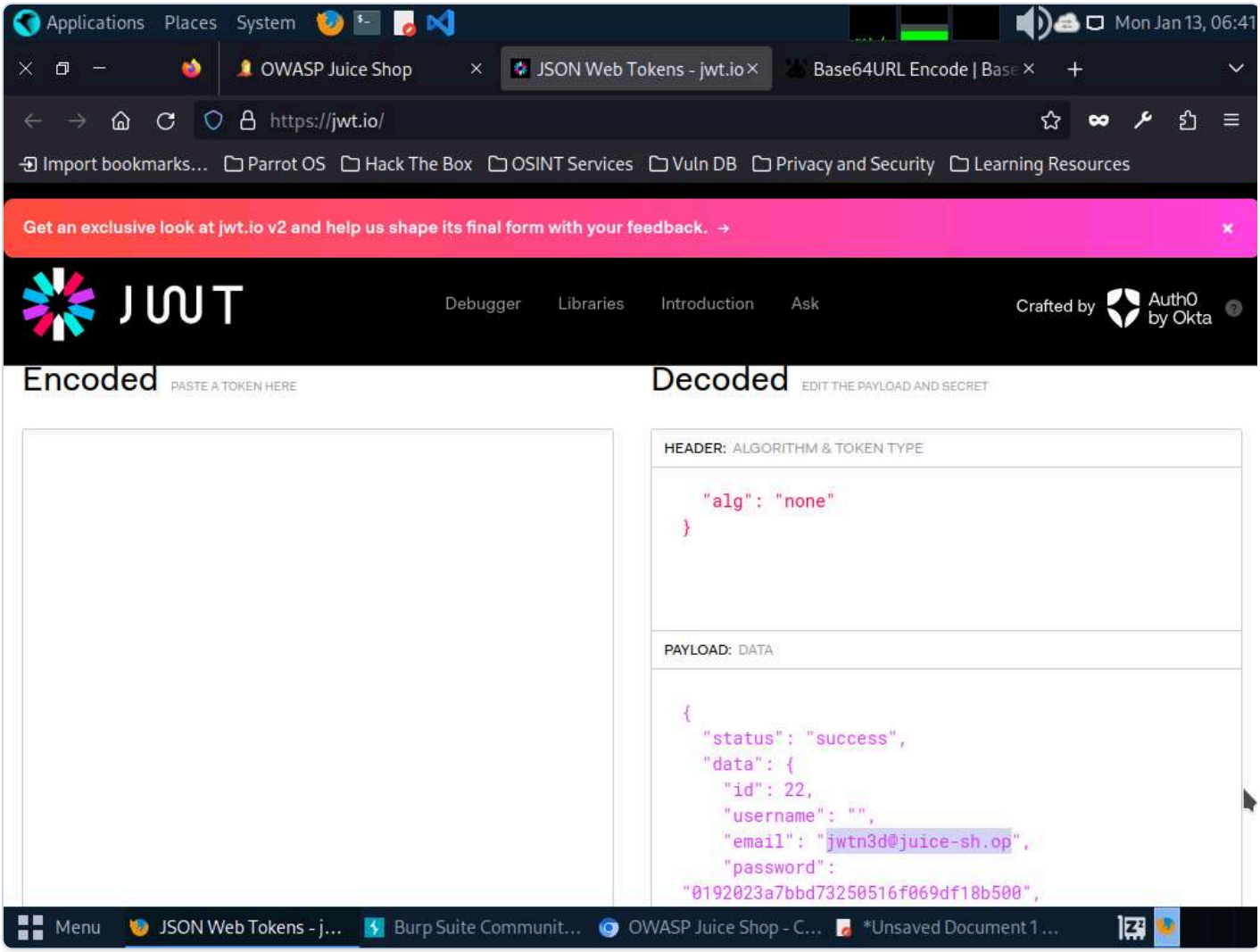

1. Copy the Base64URL-encoded header.



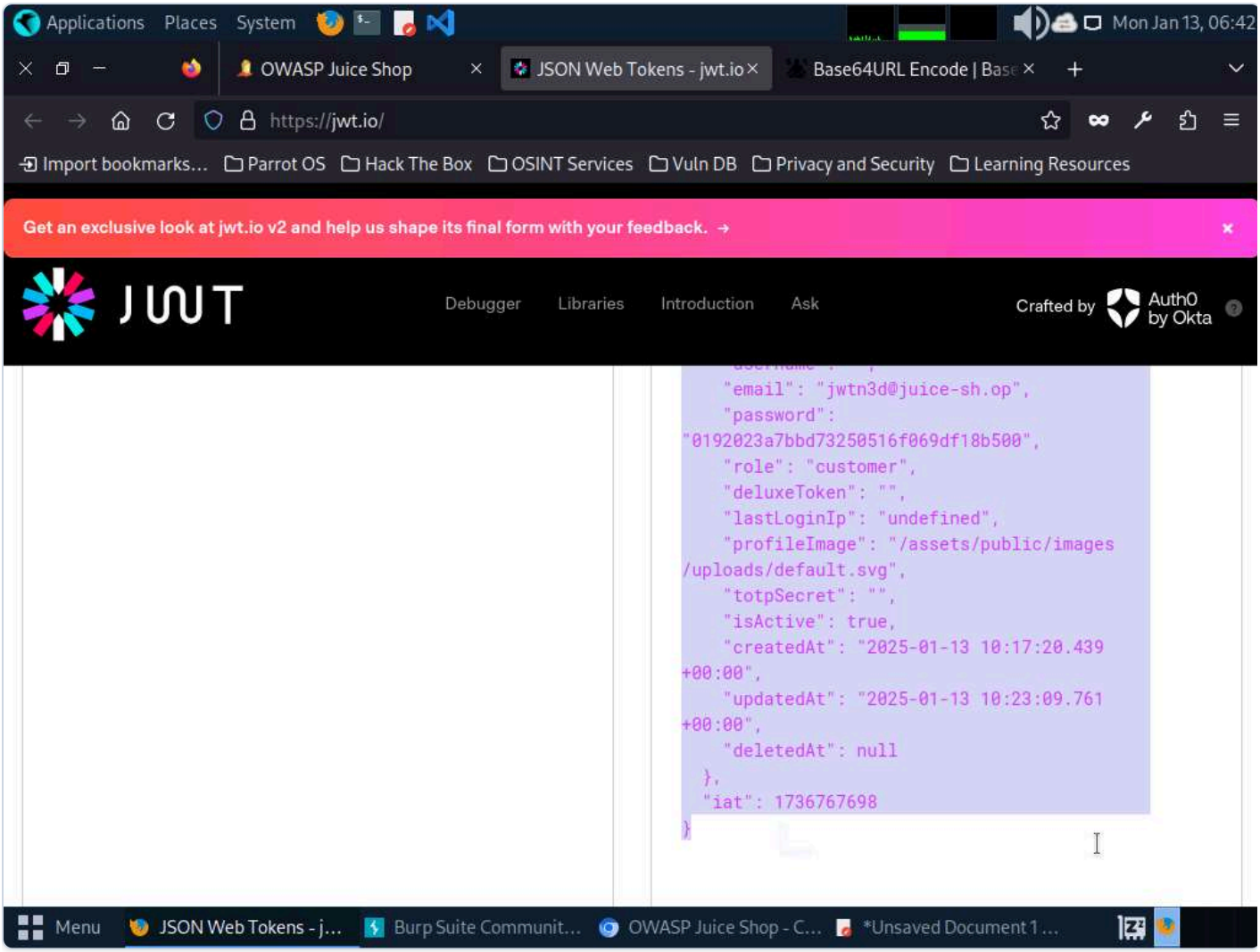

1. Open a text editor, paste the encoded header string, and append a period (`.`).



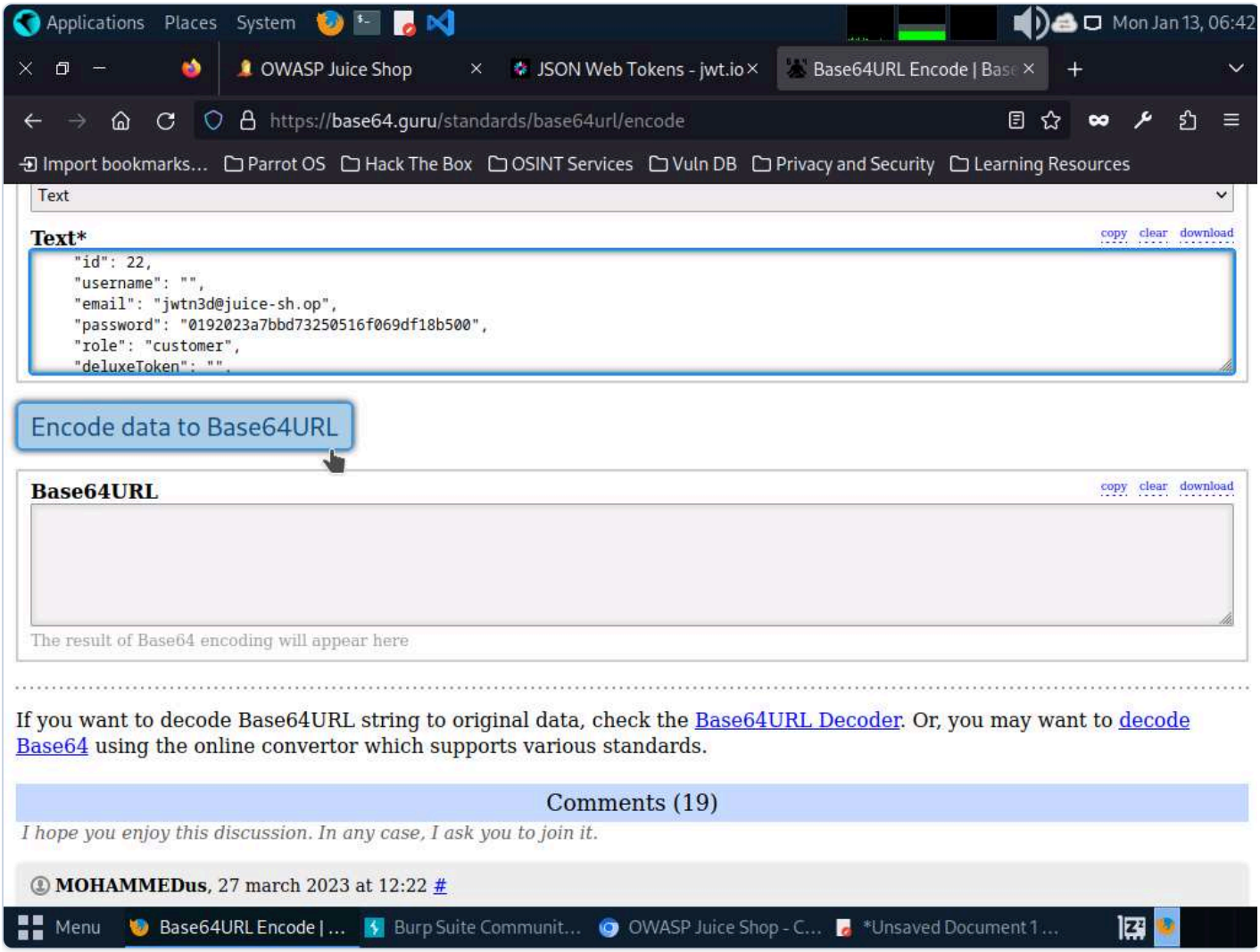

1. Return to **https://jwt.io** and modify the email payload claim to **jwtn3d@juice-sh.op**.



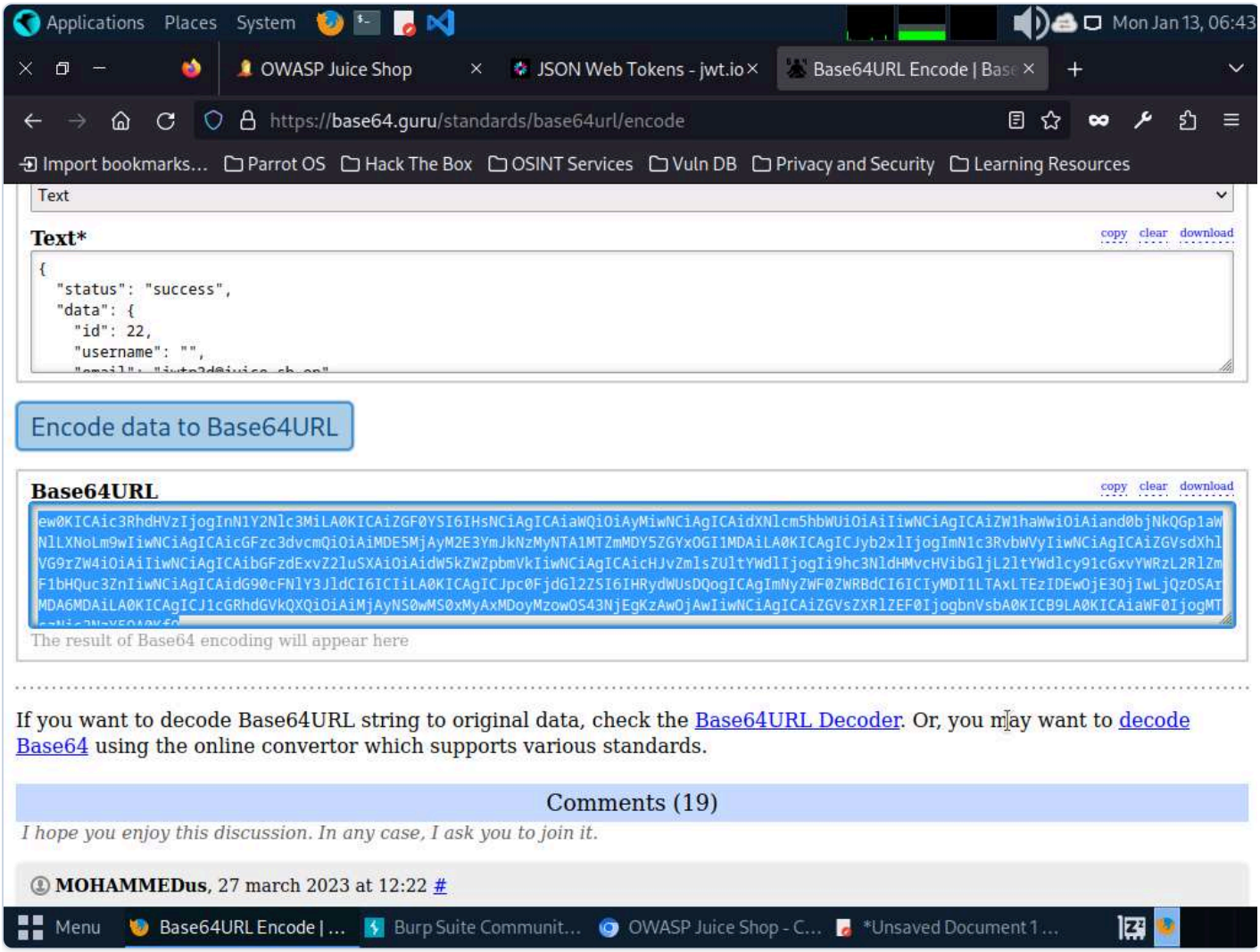

1. Copy the modified payload JSON.



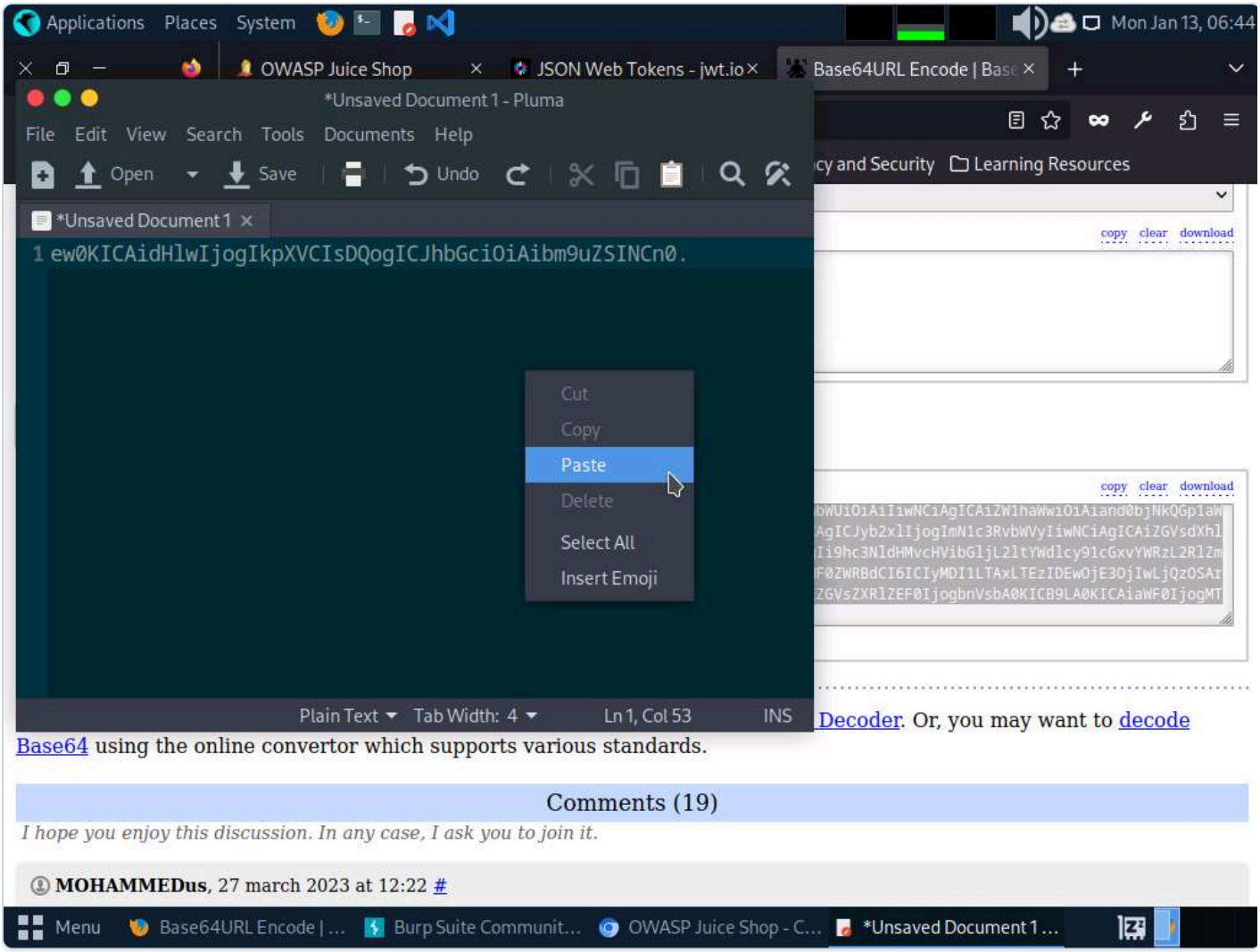

1. Return to the Base64URL encoder, paste the modified payload JSON, and encode it.



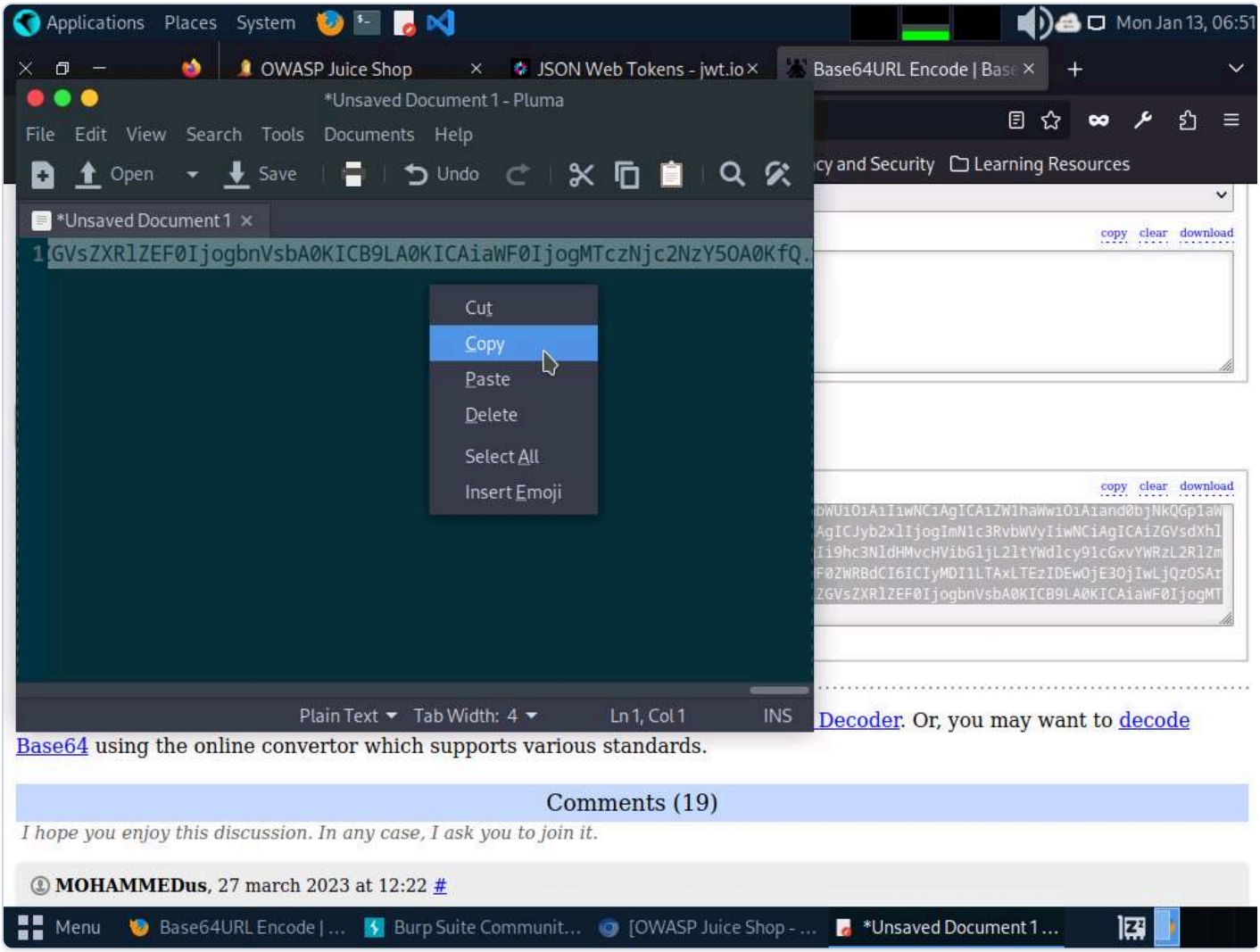

1. Copy the Base64URL-encoded payload.



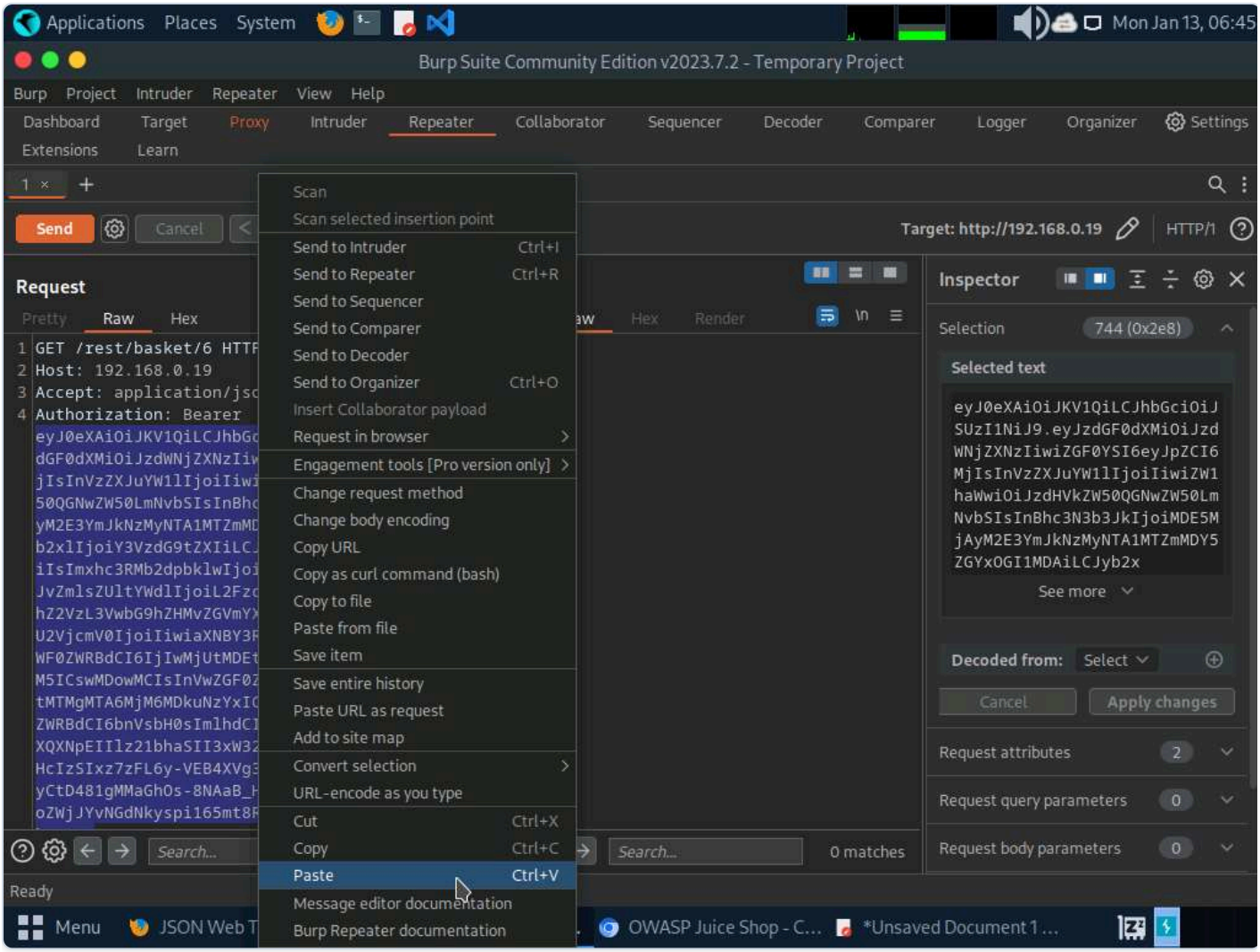

1. Paste the encoded payload after the period in your text editor.



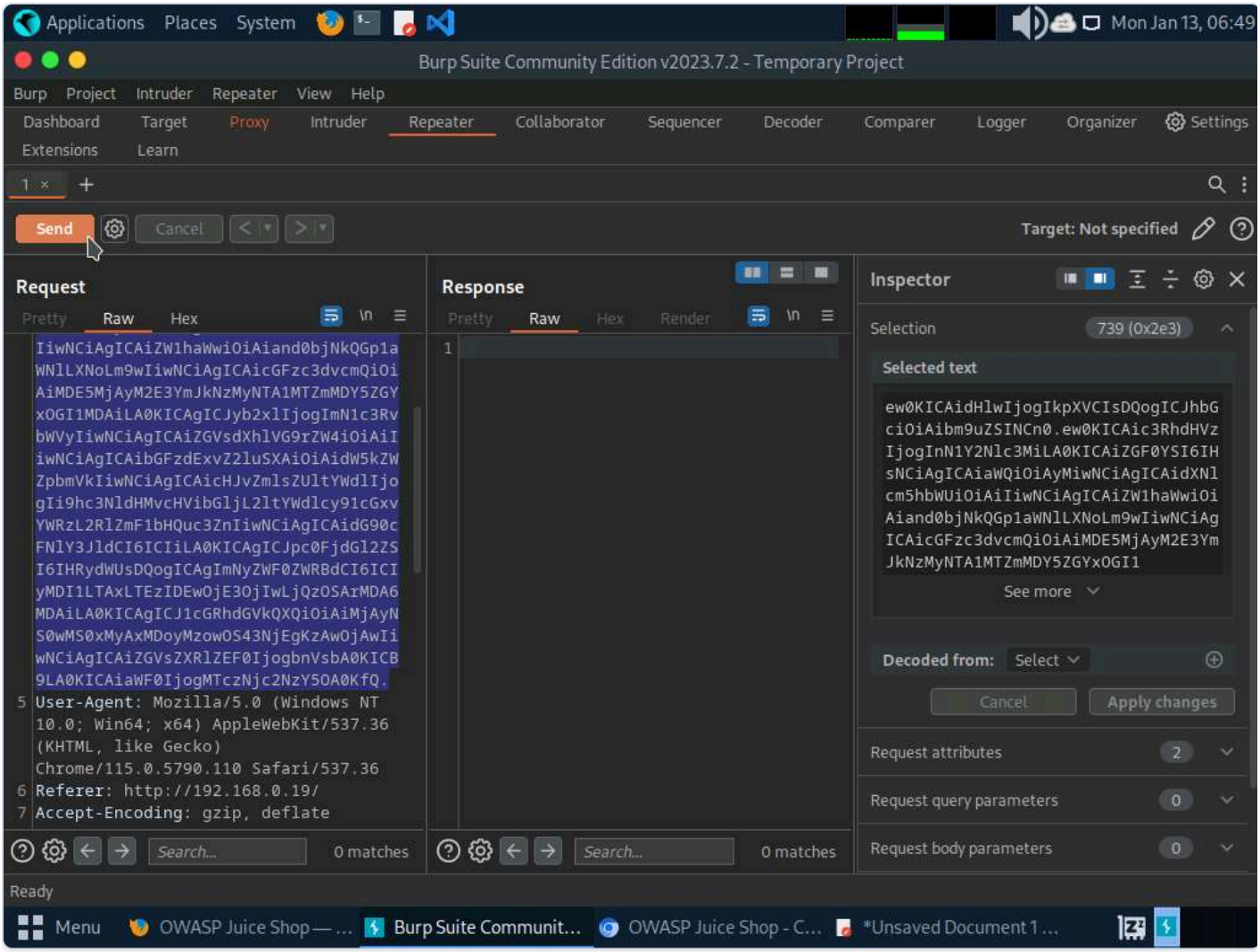

1. Append a trailing period ( `.` ) at the end of the payload string (signifying an empty signature), and copy the entire forged JWT token.



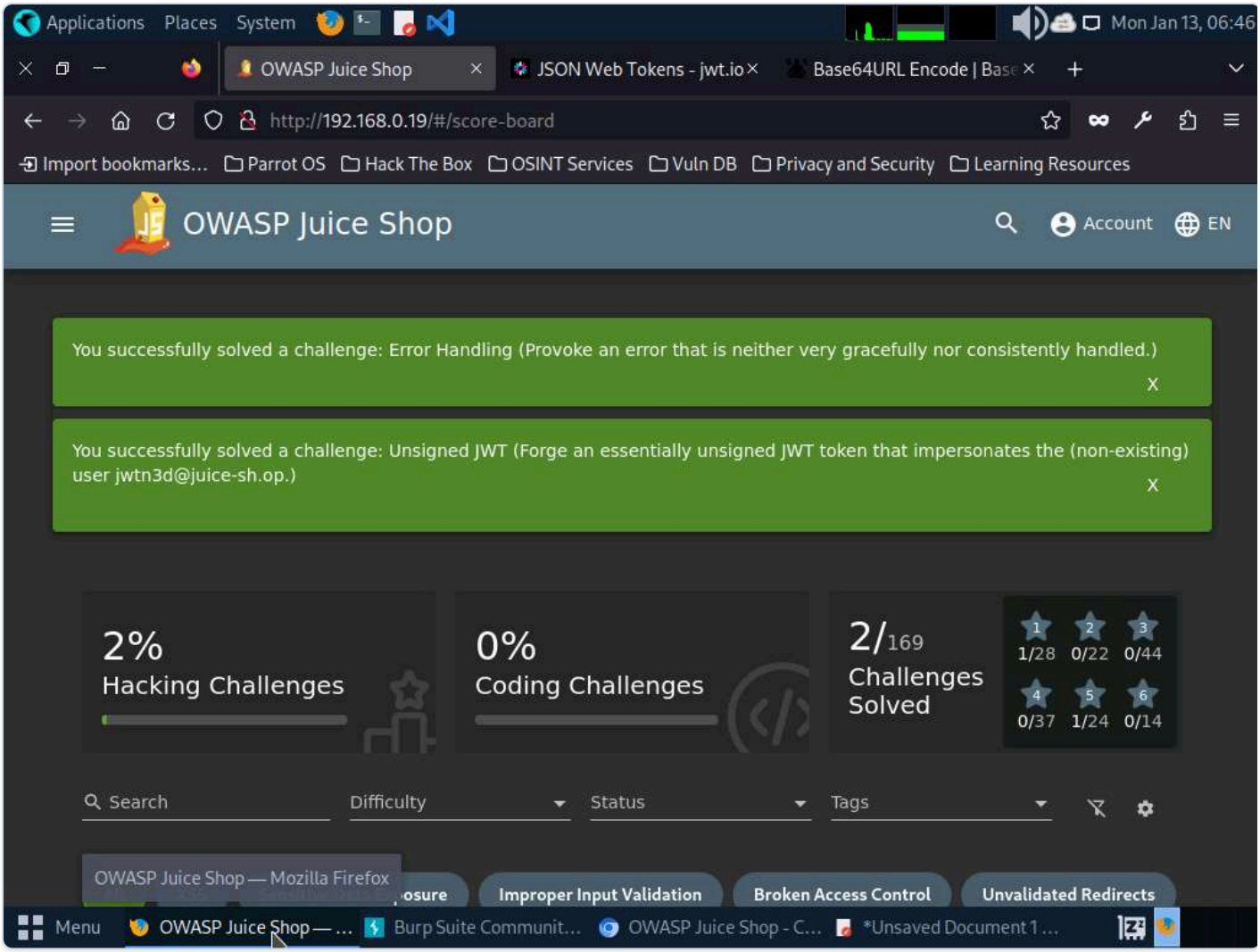

1. Switch back to Burp Repeater and replace the **Authorization: Bearer** token header value with your forged unsigned token string.




1. Click **Send** to transmit the request.




1. Switch to Firefox and refresh **http://192.168.0.19/#/score-board** to confirm challenge completion (*Forged Unsigned JWT*).




1. Close all browser and Burp Suite windows.

This concludes the lab exercise.

---

**IMPORTANT:** ❓ **Question 6.5.1.1** Using the Parrot Security operating system, utilize Burp Suite to intercept network traffic and employ jwt.io to generate an unsigned JSON Web Token (JWT) for a non-existent user. What is the default signed algorithm of the JWT token in jwt.io? [!SUCCESS] ✅ **Answer:** **RS256**